



Security findings. Human decisions. Traceable evidence.

AI AGENT + MCP SECURITY REVIEW

Scan 3aee3f5aad12ec331e99499fa4662eb21877841e2075c652fdc44c401e4306d4

Critical/high findings need prompt review

The scanner found 7 open critical/high patterns among 10 open findings. Confirm exposure and prioritize the actions below. Detector severity is not proof of exploitability or deployed risk.

10

OPEN FINDINGS

0

COVERAGE GAPS

3

FILES EXAMINED

Observed counts only. This is not an accuracy score or a security grade.

This PDF contains interactive review fields and the exact bound review workspace as an attachment. Decisions are human assertions, not verified passes. Justified/disabled items are excluded from active denominators; gaps cannot be waived.

Save an edited copy and import it through Invarune. The importer checks origin/evidence bindings, canonical form data, widget relationships and appearances. Changed source, stale appearances or ambiguous fields are rejected.



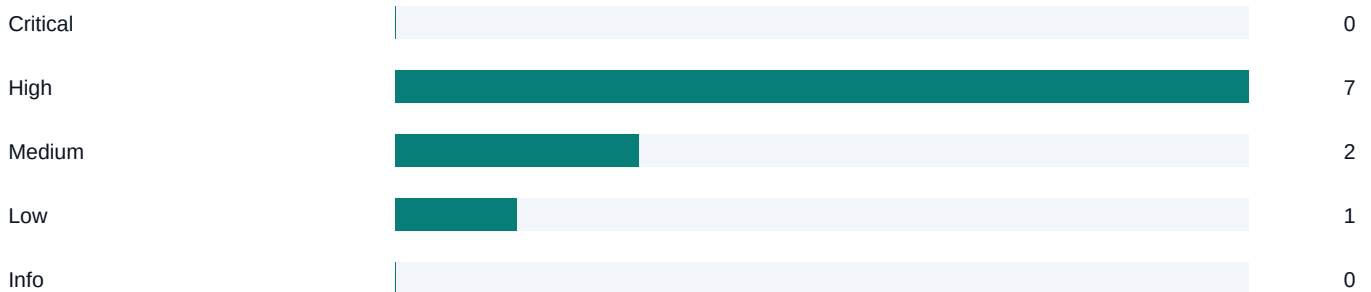
Contents

Contents	2
Executive summary	3
Scan configuration and scope	4
Deterministic checks and optional review	5
Coverage, misses and validation by area	6
Deterministic rule inventory	8
Observed findings and mitigating layers	11
Coverage gaps and required validation	18
Interactive review workspace	19
Control checklist and evidence requirements	91



Executive summary

Severity counts describe observed open patterns. They do not establish exploitability or an estimated probability of compromise.



Severity counts use the existing scanner rules; no model or reviewer score is added.

AI001 / Dynamic Python code execution

Trace the input to eval/exec and replace it with fixed operations; if generated execution is essential, isolate it before accepting untrusted input.

AI003 / Dynamic os shell command

Replace os.system/os.popen with a fixed executable and validated argument list; trace all contributing values.

AI005 / Executable deserialization requires trusted inputs

Establish who can produce and replace the input; migrate to a nonexecutable data format or restrict verified legacy artifacts to an isolated conversion path.

AI006 / TLS certificate verification disabled

Enable certificate and hostname verification; install the intended CA for a private gateway and test rejection of an untrusted certificate.

AI010 / Credential-like literal in source or configuration

Determine whether the value is real without reproducing it; revoke or rotate a real exposed credential and remove retained copies through the incident process.

AI029 / Remote MCP URL uses plaintext HTTP

Use HTTPS with verified certificates; if a separate protected transport is intentional, document and test every network hop and termination boundary.

AI031 / Agent approval or sandbox safeguard explicitly bypassed

Review the effective permission policy and restore bounded tools and runtime isolation; require independent approval for the specific sensitive effects.

AI018 / MCP package runner resolves an unpinned artifact

Resolve and approve exact executable and transitive artifacts, enforce the lock at launch, and minimize inherited environment secrets.

Review every detailed finding and gap below. Additional concerns can exist outside this bounded scan's supported syntax, files, budgets and execution context.



Scan configuration and scope

Source scope and limits

default_excluded_directories: [".cache", ".git", ".hg", ".mypy_cache", ".next", ".pytest_cache", ".svn", ".tox", ".venv", "__pycache__", "build", "coverage", "dist", "node_modules", "vendor", "venv"]

exclude: []

explicit_exclusion_identity_scope: "Existing selected files and directories, including case aliases and file hardlinks; inputs must remain stable during the scan. Device/inode identities are not persisted in reports."

explicit_exclusion_matching: "resolved_paths_and_snapshot_filesystem_identities"

generated_outputs_and_judge_config_excluded: true

max_entries: 100000

max_file_bytes: 1000000

max_files: 20000

max_total_bytes: 50000000

review_config_sha256: "465365cee27f267d542b1f7f62a158d5c7cef210a8ff1f7a4a22b2a251ad55fb"

Invocation and optional-review budgets

optional_review: {"analyst_limits": {"batch_size": 6, "max_bytes": 2000000, "max_calls": 12, "max_chars": 120000, "max_files": 200, "max_seconds": 180}, "cli_login": "auto", "cli_timeout_seconds": null, "effective_transport": {}, "enabled": false, "findings_limit": 100, "include_finding_source": false, "mode": "full", "provider": null, "transport_replay": "Endpoints, credentials, headers, executable paths and identity stores are not embedded for automatic replay."}

reporting: {"failure_threshold": "high", "formats": ["html", "markdown", "json", "sarif", "pdf"]}

review_inputs: {"baseline": false, "review_config": false, "review_report": true}

schema_version: "1.0"

Image limits

Not present for this scan.

Source and image evidence are static. Image metadata, retained layers and packaged files do not reveal every runtime override or compiled program behavior.

Tool provenance: {"display_name": "Invarune by NimeshBuild", "implementation_sha256": "c3687f2f37a248daefd6b182e9fc6c4330985f26d71252dfa5a42c336a3ec228", "name": "agent-mcp-security-scan", "python_version": "3.12.14", "version": "0.9.0"}



Deterministic checks and optional review

42 static source/configuration patterns

Deterministic checks inspect bounded Python syntax and local value flow, JavaScript/TypeScript lexical structure, structured JSON, configuration settings, selected secret patterns and image metadata. Repeated stable input produces repeatable evidence; it does not guarantee zero false positives or negatives.

Optional security analyst

If enabled, a model reviews selected findings and acceptance checks using bounded supplied evidence. Strict IDs, citations, response validation and tool restrictions constrain the protocol. Partial budgets, omitted answers and unavailable source/runtime evidence remain visible. Advice does not independently prove safety or erase static findings.

```
{"analyst": {"enabled": false}, "judge": {"enabled": false}}
```

What can be missed

Cross-module/interprocedural flow, reflection, dynamic loaders, complex language syntax, templates before rendering, unsupported languages, compiled image behavior, runtime authentication/authorization, tenant isolation, egress policy, dependency CVEs and adaptive prompt injection require additional validation. A source declaration or proposed mitigation is not deployment evidence.

Human/runtime review workflow



1. Review evidence and the immediate concern. 2. Record a decision, reason, reviewer, date and evidence reference. 3. Validate runtime or human-dependent controls in the applicable environment. 4. Save and import the edited PDF or equivalent JSON. 5. Resolve rejected/stale edits, then rescan. Gaps remain operationally incomplete; blank decisions retain existing scanner semantics.



Coverage, misses and validation by area

Controls with rule mapping		26
Controls without rule mapping		40

Catalog mapping counts are not passed controls or percent secure.

Mapping counts describe available checks, not percent secure, detection accuracy or validated control effectiveness.

Execution and data flow

Deterministic: Python AST checks with bounded local aliases/values; JavaScript/TypeScript tokens and balanced calls identify selected eval, shell, deserialization, SQL and template patterns.

Optional analyst: A model can explain a retrieved call path, question whether input is trusted and identify contextual concerns the pattern rules do not encode.

Can miss or misclassify: Cross-file flows, dynamic imports, wrappers, reflection, generated code, unsupported languages and runtime values can hide a risk. A dangerous API can also be intentional and correctly constrained.

Validate elsewhere: Exercise actual entry points with authorized negative tests; verify input provenance, execution privileges and sandbox boundaries.

MCP identity, authorization and tools

Deterministic: Selected configuration/code signals flag insecure transport, explicit authentication bypass, token passthrough, broad tool grants and unpinned server launch packages.

Optional analyst: A model can review supplied authorization logic, tool descriptions and trust-boundary evidence for missing assumptions or inconsistent checks.

Can miss or misclassify: Configuration may differ from deployment. External gateways, identity providers, token audience checks and tenant boundaries may be absent from retrieved evidence.

Validate elsewhere: Test expired/wrong-audience tokens, cross-tenant access, per-tool authorization, consent binding and the deployed MCP transport.

Prompt injection, retrieval and memory

Deterministic: Selected patterns identify external content placed in privileged model messages and explicit approval/sandbox bypass. This is not an attack simulation.

Optional analyst: A model can reason about untrusted-content handling, persistent memory, tool-output influence and missing approval boundaries in the supplied excerpts.

Can miss or misclassify: Adaptive attacks, multi-turn interactions and tool chains depend on runtime behavior. Retrieval can omit the relevant code; a model can overlook an attack or be influenced by hostile evidence.

Validate elsewhere: Run isolated adversarial agent/MCP evaluations with attack-success and legitimate-task measurements, plus human review of consequential actions.

Secrets and data handling

Deterministic: Selected literal credentials, plausible private-key material, credential-bearing URLs, logging patterns and browser credential exposure are flagged and redacted best-effort.

Optional analyst: A model can identify sensitive data flows and retention concerns when the supplied evidence explains their context.

Can miss or misclassify: Encoded, split or runtime-fetched credentials can be missed; labels/test values can resemble secrets. Neither layer establishes whether a credential is live or redaction is complete.

Validate elsewhere: Verify secret stores, credential rotation, logging/retention policy, egress destinations and actual data-access permissions.

Built images and supply chain

Deterministic: Image archives are reconstructed without starting containers; supported packaged source, metadata, retained credentials, stored permissions and package inventories are inspected.

Optional analyst: A model can interpret supplied image/source evidence, flag missing deployment context and propose verification work.

Can miss or misclassify: Compiled logic, live deployment overrides, signature trust and dependency CVEs are not assessed. Package inventory and archive consistency do not establish safety or publisher identity.

Validate elsewhere: Use vulnerability/advisory analysis, provenance/signature verification and deployment testing alongside the static image assessment.



Operations and control effectiveness

Deterministic: The catalog retains governance, monitoring, recovery, approval and isolation checks even where no deterministic rule maps to them.

Optional analyst: Full review queues every active acceptance check and can identify evidence gaps or propose runtime/human validation; it can cite exact submitted source text.

Can miss or misclassify: A valid citation proves that a quote exists, not that the model's interpretation is correct. Policies, external services, incident procedures and production outcomes may be unavailable.

Validate elsewhere: Record owner-reviewed evidence, operational exercises and runtime results. A written justification remains an accepted exception, never an automatically validated pass.



Deterministic rule inventory

AI001 / Dynamic Python code execution

eval or exec receives a nonliteral expression. If agent, user, or tool content can reach it, it can execute arbitrary Python. Static analysis does not establish the full data flow.

AI002 / Dynamic command executed through a shell

A subprocess call enables a shell, invokes a shell-specific API, or passes a dynamic command to an explicit shell executable. Shell metacharacters in agent or external input may become executable syntax.

AI003 / Dynamic os shell command

os.system or os.popen executes a dynamically constructed command through the shell. Review the command's trust boundary.

AI004 / Unsafe YAML object construction

YAML is loaded through an unsafe loader or without an explicitly safe loader. Older or unsafe loaders can construct Python objects from input.

AI005 / Executable deserialization requires trusted inputs

Pickle-compatible deserialization can execute code. This finding identifies a dangerous trust boundary, not proof that the serialized input is attacker controlled.

AI006 / TLS certificate verification disabled

Certificate verification is explicitly disabled. A network intermediary may impersonate the remote service and capture prompts, credentials, or tool results.

AI007 / Wildcard cross-origin access

Cross-origin access explicitly permits every origin. For credential-bearing or local MCP services this can expose a browser-accessible trust boundary; reachability and framework behavior require review.

AI008 / Service binds to all network interfaces

A server explicitly binds to a wildcard address. This is a deployment review signal: source alone cannot establish actual network reachability or authentication.

AI009 / Application debug mode enabled

Debug mode is explicitly enabled in server code or configuration. Depending on the framework and deployment, error details or a debugger may become externally accessible.

AI010 / Credential-like literal in source or configuration

A credential-named field contains a nonplaceholder literal. It may be a real secret or test data; validate it without disclosing the value.

AI011 / Private key material in repository

A private-key PEM header is followed by plausible encoded key material. Test keys may be intentional; this pattern does not prove cryptographic validity or production use.

AI012 / Dynamic JavaScript shell execution

A Node child-process shell execution API receives a dynamic command. Agent or external content reaching this value may inject shell syntax.

AI013 / Dynamic JavaScript code execution

eval or the Function constructor evaluates a dynamic value as JavaScript. Review whether user, agent, or tool data can cross this execution boundary.

AI014 / Externally influenced outbound request

An outbound request uses an obvious external-input expression. This is a review signal for SSRF; this local analysis cannot prove whether upstream URL validation exists.

AI015 / Externally influenced filesystem path

A filesystem operation consumes an obvious external-input expression. Review whether canonical path checks and symlink handling confine access to the intended workspace.

AI016 / Race-prone temporary filename creation

tempfile.mktemp returns an unused name without atomically creating the file, allowing a race with another local process.



AI017 / JWT verification explicitly bypassed

JWT decoding explicitly disables signature verification or selects the none algorithm. Unverified claims must never authorize agent or MCP operations.

AI018 / MCP package runner resolves an unpinned artifact

An MCP launch configuration uses npx, uvx, or a similar ephemeral package runner without an exact package version. The executable artifact can change between launches.

AI019 / Remote download piped directly to a shell

Downloaded content is directly piped to a shell. A changed or compromised remote artifact becomes executable without a visible integrity check.

AI020 / GitHub Action reference is not pinned to a commit

A remote GitHub Action is referenced using a mutable tag, branch, or noncommit reference. Its code can change without a workflow diff.

AI021 / Container explicitly runs as root

The default final Dockerfile stage explicitly selects or inherits a literal root user. Build-target selection, external image defaults, variable expansion and runtime overrides require separate validation.

AI022 / Privileged container or privilege escalation enabled

Container configuration explicitly enables privileged execution or privilege escalation, weakening isolation for tool or agent code.

AI023 / Container runtime socket exposed

A container runtime socket is present in configuration. A writable Docker or containerd socket can give a tool control over host workloads.

AI024 / Container image is not digest pinned

A container base or deployment image uses a mutable reference rather than a content digest. The bytes can change between builds or deployments.

AI025 / Direct dependency is not exactly pinned

A direct dependency declaration allows version movement. A lockfile elsewhere may constrain the actual installation; review the effective build process.

AI026 / Authentication explicitly disabled

An MCP or server configuration explicitly disables an authentication-related control. Local stdio servers may rely on an operating-system boundary; assess the actual transport and exposure.

AI027 / Wildcard tool or permission authorization

An authorization or tool allowlist explicitly grants a wildcard or all-tools capability. This may give an agent broader authority than its task requires.

AI028 / MCP token passthrough enabled

Configuration explicitly enables token passthrough or token forwarding. Forwarding an inbound token to an unrelated downstream audience can bypass consent and authorization boundaries.

AI029 / Remote MCP URL uses plaintext HTTP

An MCP configuration points to a nonloopback HTTP URL. Credentials, tool requests, and results may be exposed in transit; network-layer protection is not established by this scan.

AI030 / Browser-side API credential access explicitly enabled

An SDK explicitly enables browser execution despite credential-exposure safeguards. Verify that a durable privileged API key cannot reach client-side code.

AI031 / Agent approval or sandbox safeguard explicitly bypassed

An agent configuration or command explicitly disables approvals or enables unrestricted execution. The impact depends on the process identity, tools, and sandbox.

AI032 / External data inserted into privileged LLM instructions

A system or developer message contains an obvious external-input expression. Untrusted data may be interpreted as privileged instructions; local analysis cannot establish exploitability.

AI033 / Potential secret included in logging call

A logging call directly references a credential-named variable or field. Log processors and retention can broaden access to secrets.

AI034 / Credential-like value embedded in URL query

A URL contains a credential-like query parameter with a nonplaceholder value. URLs can be retained in logs, histories, proxies, and telemetry.



AI035 / Unsafe model checkpoint deserialization

torch.load explicitly sets weights_only=False or a framework disables safe model loading. An untrusted artifact may contain executable object deserialization.

AI036 / SQL query constructed with interpolation

A database execution call receives an interpolated or concatenated SQL expression. If untrusted content contributes, it may change the query's meaning.

AI037 / Archive extraction without an explicit safe filter

A tar extraction call has no explicit safe data filter, or selects a fully trusted filter. Behavior depends on the Python version and archive provenance.

AI038 / Cryptographically weak randomness used for a security value

A credential-, nonce-, or token-named assignment uses a general-purpose random generator. Predictability matters if the value protects access or replay prevention.

AI039 / Server-Side Template rendered from a dynamic template

A server-side template string is dynamically supplied. If agent or user content controls template source, template expressions may execute with server privileges.

AI040 / Unsafe HTML rendering boundary

Dynamic content is passed to an HTML rendering bypass. Agent or tool-generated content may contain executable browser markup if not sanitized.

AI041 / MCP inspector authorization explicitly disabled

The MCP inspector's authorization safeguard is explicitly disabled. A reachable inspector may provide access to connected tools and their privileges.

AI042 / Container uses host namespaces

Container configuration explicitly uses the host PID namespace or host networking. This weakens separation between agent tooling and the host.



Observed findings and mitigating layers

AI002 / high / justified

Dynamic command executed through a shell

agent.py:9

```
subprocess.run(user_command, shell=True)
```

Pass an argument list with shell=False, allowlist executable names and options, and enforce working-directory and resource restrictions.

AI003 / high / open

Dynamic os shell command

agent.py:10

```
os.system(user_command)
```

Use subprocess with a fixed executable and argument list, shell=False, and explicit allowed options.

AI006 / high / open

TLS certificate verification disabled

agent.py:11

```
data = requests.get(remote_url, verify=False)
```

Enable certificate verification and install the correct CA bundle; use a trusted private CA for custom gateways.

AI005 / high / open

Executable deserialization requires trusted inputs

agent.py:12

```
return pickle.loads(serialized_data), data.text
```

Use a nonexecutable serialization format with schema validation. If compatibility requires pickle, accept only authenticated artifacts from a strictly controlled producer.

AI001 / high / open

Dynamic Python code execution

agent.py:16

```
return eval(model_response)
```

Replace dynamic execution with an allowlisted operation dispatcher; use ast.literal_eval only for bounded literal parsing. Isolate unavoidable execution with no ambient credentials and strict resource limits.

AI010 / high / open

Credential-like literal in source or configuration

mcp.json:6

```
[REDACTED: credential-related source evidence; inspect this location locally]
```

If real, revoke and rotate the credential, remove it from source and history, and load it from a secret manager or environment variable with least privilege.

AI031 / high / open

Agent approval or sandbox safeguard explicitly bypassed

mcp.json:7

```
"autoApprove": ["*"]
```

Use bounded tool permissions and an isolated runtime; require deliberate approval for destructive, external, financial, or credential-bearing actions.

AI029 / high / open

Remote MCP URL uses plaintext HTTP

mcp.json:10

```
"url": "http://mcp.example.invalid/mcp"
```



Use HTTPS with certificate verification for remote MCP endpoints. Reserve plaintext HTTP for explicitly controlled local development or a documented protected transport.

AI021 / medium / open

Container explicitly runs as root

Dockerfile:2

USER root

COPY . /app

Use a dedicated nonroot runtime user and minimal capabilities; verify the final build stage and deployment security context.

AI018 / medium / open

MCP package runner resolves an unpinned artifact

mcp.json:4

"command": "npx",

Pin an exact audited package version and lock or verify transitive artifacts. Prefer preinstalled verified tools in a controlled environment.

AI024 / low / open

Container image is not digest pinned

Dockerfile:1

FROM python:latest

Pin approved image digests, track provenance and SBOMs, and update through reviewed vulnerability-remediation workflows.

AI001 / Enforce action policy outside the model

Proposed control; effectiveness has not been verified.

How it helps: Have an execution service allow only named operations, permitted argument values, and caller-owned target resources before invoking a tool.

Evidence to obtain: Exercise disallowed operations, additional arguments, cross-tenant identifiers, and direct calls that bypass the agent planner.

Remaining limit: Authorized operations can still be harmful when business constraints are incomplete; prompt instructions cannot enforce this boundary.

Related controls: AGT-01, AUTH-02, MCP-02

[MCP-TOOLS / MCP: Tools](#)

[OWASP-AGENT-CS / AI Agent Security Cheat Sheet](#)

AI001 / Isolate tool execution

Proposed control; effectiveness has not been verified.

How it helps: Run the risky tool in a separate, disposable identity with no host mounts, ambient credentials, or unnecessary outbound access.

Evidence to obtain: In a test environment, attempt reads outside the workspace, forbidden network connections, and resource exhaustion; retain policy and denial evidence.

Remaining limit: Isolation limits reachable assets; it does not make injected code trustworthy or rule out a runtime escape.

Related controls: EXEC-02, SUP-05, OPS-02

[JOINT-DEPLOY / Deploying AI Systems Securely: Best Practices for Deploying Secure and Resilient AI Systems](#)

AI003 / Enforce action policy outside the model

Proposed control; effectiveness has not been verified.

How it helps: Have an execution service allow only named operations, permitted argument values, and caller-owned target resources before invoking a tool.

Evidence to obtain: Exercise disallowed operations, additional arguments, cross-tenant identifiers, and direct calls that bypass the agent planner.

Remaining limit: Authorized operations can still be harmful when business constraints are incomplete; prompt instructions cannot enforce this boundary.

Related controls: AGT-01, AUTH-02, MCP-02

[MCP-TOOLS / MCP: Tools](#)

[OWASP-AGENT-CS / AI Agent Security Cheat Sheet](#)



AI003 / Isolate tool execution

Proposed control; effectiveness has not been verified.

How it helps: Run the risky tool in a separate, disposable identity with no host mounts, ambient credentials, or unnecessary outbound access.

Evidence to obtain: In a test environment, attempt reads outside the workspace, forbidden network connections, and resource exhaustion; retain policy and denial evidence.

Remaining limit: Isolation limits reachable assets; it does not make injected code trustworthy or rule out a runtime escape.

Related controls: EXEC-02, SUP-05, OPS-02

[JOINT-DEPLOY / Deploying AI Systems Securely: Best Practices for Deploying Secure and Resilient AI Systems](#)

AI005 / Verify artifact identity before use

Proposed control; effectiveness has not been verified.

How it helps: Require reviewed artifact provenance plus a digest or signature checked against an independently trusted identity or manifest.

Evidence to obtain: Substitute bytes, producer identity, or verification metadata in a controlled test and confirm the consumer rejects the artifact.

Remaining limit: Authenticity establishes the producer and bytes; an approved producer can still ship vulnerable or malicious content.

Related controls: SUP-03, DATA-04

[OPENSSEF-MODEL-SIGNING / Launch of Model Signing v1.0](#)

[SLSA-12 / Supply-chain Levels for Software Artifacts specification](#)

AI005 / Separate artifact conversion from production

Proposed control; effectiveness has not been verified.

How it helps: Perform necessary conversion of legacy serialized artifacts in a disposable environment without production data or credentials.

Evidence to obtain: Demonstrate that a conversion job cannot reach production services and only approved output formats are promoted.

Remaining limit: Conversion output still needs integrity, format, and downstream behavior review; isolation is not proof of benign content.

Related controls: EXEC-06, SUP-06

[JOINT-DEPLOY / Deploying AI Systems Securely: Best Practices for Deploying Secure and Resilient AI Systems](#)

[TECH-PYTORCH-SERIAL / PyTorch Serialization semantics](#)

AI006 / Require authenticated encrypted transport

Proposed control; effectiveness has not been verified.

How it helps: Use verified TLS on every relevant network hop, with an appropriate public or private CA and validated service hostname.

Evidence to obtain: Present an untrusted, expired, or wrong-host certificate and verify rejection; inspect backend traffic after TLS termination.

Remaining limit: TLS does not protect data from an authorized endpoint, compromised gateway, or plaintext segments beyond termination.

Related controls: MCP-01, AUTH-05

[MCP-AUTH / MCP: Authorization](#)

[MCP-AUTH-SEC / MCP: Authorization Security Considerations](#)

AI006 / Restrict outbound destinations independently

Proposed control; effectiveness has not been verified.

How it helps: Enforce an outbound policy outside the application that permits only required destinations and services; include IPv6 and proxy paths.

Evidence to obtain: From the deployed identity, test direct IP, DNS, redirect, metadata-service, and proxy-mediated attempts to prohibited destinations.

Remaining limit: Allowed destinations may themselves accept leaked data; destination rules do not replace content and action authorization.

Related controls: EXEC-05, AGT-07, SUP-05

[JOINT-DEPLOY / Deploying AI Systems Securely: Best Practices for Deploying Secure and Resilient AI Systems](#)

[MCP-SECURITY / MCP Security Best Practices](#)



AI010 / Investigate and contain confirmed secret exposure

Proposed control; effectiveness has not been verified.

How it helps: For a real exposed credential, identify reachable systems, revoke or rotate it, and review access records for misuse.

Evidence to obtain: Confirm the old credential no longer works and record the exposure window, affected copies, and follow-up owner.

Remaining limit: Successful rotation stops future use of that credential but cannot reverse access or data loss that already occurred.

Related controls: AUTH-05, OPS-06

[CISA-JCDC / JCDC AI Cybersecurity Collaboration Playbook and Fact Sheet \(release notice\)](#)

[NIST-SSDF / Secure Software Development Framework \(SSDF\) Version 1.1](#)

AI010 / Use managed credential injection and revocation

Proposed control; effectiveness has not been verified.

How it helps: Load secrets at runtime through an approved store or workload identity; keep them out of source, artifacts, and model context.

Evidence to obtain: Test rotation and revocation without disclosing values; inspect build layers and launch metadata for retained copies.

Remaining limit: Deleting a file or hiding a later image layer does not revoke a credential or erase copies already distributed.

Related controls: AUTH-05, DATA-01, DATA-06

[JOINT-AGENTIC / Careful adoption of agentic AI services](#)

[MCP-AUTH / MCP: Authorization](#)

AI010 / Limit credentials available to the workload

Proposed control; effectiveness has not been verified.

How it helps: Give this component a distinct identity and only the downstream scopes and lifetime needed for its approved operations.

Evidence to obtain: Use its runtime identity to attempt forbidden service operations, then revoke it and confirm subsequent access fails.

Remaining limit: A compromised component can still use its allowed permissions until credentials expire or revocation takes effect.

Related controls: AUTH-05, AUTH-09

[JOINT-AGENTIC / Careful adoption of agentic AI services](#)

AI029 / Require authenticated encrypted transport

Proposed control; effectiveness has not been verified.

How it helps: Use verified TLS on every relevant network hop, with an appropriate public or private CA and validated service hostname.

Evidence to obtain: Present an untrusted, expired, or wrong-host certificate and verify rejection; inspect backend traffic after TLS termination.

Remaining limit: TLS does not protect data from an authorized endpoint, compromised gateway, or plaintext segments beyond termination.

Related controls: MCP-01, AUTH-05

[MCP-AUTH / MCP: Authorization](#)

[MCP-AUTH-SEC / MCP: Authorization Security Considerations](#)

AI029 / Limit credentials available to the workload

Proposed control; effectiveness has not been verified.

How it helps: Give this component a distinct identity and only the downstream scopes and lifetime needed for its approved operations.

Evidence to obtain: Use its runtime identity to attempt forbidden service operations, then revoke it and confirm subsequent access fails.

Remaining limit: A compromised component can still use its allowed permissions until credentials expire or revocation takes effect.

Related controls: AUTH-05, AUTH-09

[JOINT-AGENTIC / Careful adoption of agentic AI services](#)



AI031 / Enforce action policy outside the model

Proposed control; effectiveness has not been verified.

How it helps: Have an execution service allow only named operations, permitted argument values, and caller-owned target resources before invoking a tool.

Evidence to obtain: Exercise disallowed operations, additional arguments, cross-tenant identifiers, and direct calls that bypass the agent planner.

Remaining limit: Authorized operations can still be harmful when business constraints are incomplete; prompt instructions cannot enforce this boundary.

Related controls: AGT-01, AUTH-02, MCP-02

[MCP-TOOLS / MCP: Tools](#)

[OWASP-AGENT-CS / AI Agent Security Cheat Sheet](#)

AI031 / Bind sensitive actions to explicit approval

Proposed control; effectiveness has not been verified.

How it helps: Require an independent approval for the exact actor, tool, normalized arguments, target, and expiry before irreversible effects occur.

Evidence to obtain: Change arguments after approval, replay the approval, and call after expiry; each attempt must be denied before a side effect.

Remaining limit: Approval cannot compensate for misleading previews, excessive approver authority, or actions that happen before the check.

Related controls: AGT-02, OPS-04

[OWASP-AGENT-CS / AI Agent Security Cheat Sheet](#)

AI031 / Isolate tool execution

Proposed control; effectiveness has not been verified.

How it helps: Run the risky tool in a separate, disposable identity with no host mounts, ambient credentials, or unnecessary outbound access.

Evidence to obtain: In a test environment, attempt reads outside the workspace, forbidden network connections, and resource exhaustion; retain policy and denial evidence.

Remaining limit: Isolation limits reachable assets; it does not make injected code trustworthy or rule out a runtime escape.

Related controls: EXEC-02, SUP-05, OPS-02

[JOINT-DEPLOY / Deploying AI Systems Securely: Best Practices for Deploying Secure and Resilient AI Systems](#)

AI018 / Resolve and install reviewed dependency bytes

Proposed control; effectiveness has not been verified.

How it helps: Use a committed lock or approved artifact manifest, enforce it during installation, and retain the resolved dependency inventory.

Evidence to obtain: Build in a clean environment and compare resolved bytes; modify a lock or artifact and verify the release gate rejects it.

Remaining limit: An exact version or digest can still identify a vulnerable artifact; mutable transitive dependencies must also be constrained.

Related controls: SUP-01, SUP-03

[NIST-SSDF / Secure Software Development Framework \(SSDF\) Version 1.1](#)

[OPENSSEF-BASELINE-202608 / Open Source Project Security Baseline](#)

AI018 / Verify artifact identity before use

Proposed control; effectiveness has not been verified.

How it helps: Require reviewed artifact provenance plus a digest or signature checked against an independently trusted identity or manifest.

Evidence to obtain: Substitute bytes, producer identity, or verification metadata in a controlled test and confirm the consumer rejects the artifact.

Remaining limit: Authenticity establishes the producer and bytes; an approved producer can still ship vulnerable or malicious content.

Related controls: SUP-03, DATA-04

[OPENSSEF-MODEL-SIGNING / Launch of Model Signing v1.0](#)

[SLSA-12 / Supply-chain Levels for Software Artifacts specification](#)

AI018 / Limit credentials available to the workload

Proposed control; effectiveness has not been verified.

How it helps: Give this component a distinct identity and only the downstream scopes and lifetime needed for its approved operations.

Evidence to obtain: Use its runtime identity to attempt forbidden service operations, then revoke it and confirm subsequent access fails.

Remaining limit: A compromised component can still use its allowed permissions until credentials expire or revocation takes effect.

Related controls: AUTH-05, AUTH-09

[JOINT-AGENTIC / Careful adoption of agentic AI services](#)



AI021 / Apply runtime isolation controls together

Proposed control; effectiveness has not been verified.

How it helps: Use a dedicated nonroot identity, minimal capabilities, no privilege escalation, and an enforced syscall and mandatory-access policy where supported.

Evidence to obtain: Inspect the effective workload and attempt privileged operations, prohibited syscalls, and access to protected host resources.

Remaining limit: Nonroot alone is insufficient; writable mounts, added capabilities, host namespaces, and kernel flaws can weaken isolation.

Related controls: SUP-05, TEST-05

[CIS-CONTROLS-81 / CIS Critical Security Controls v8.1](#)

[JOINT-DEPLOY / Deploying AI Systems Securely: Best Practices for Deploying Secure and Resilient AI Systems](#)

AI021 / Separate risky tools from sensitive workloads

Proposed control; effectiveness has not been verified.

How it helps: Place tools needing exceptional privileges in a separate environment with narrow interfaces and no unrelated tenant data.

Evidence to obtain: Test cross-workload network and filesystem access and confirm the privileged component cannot impersonate the requesting agent.

Remaining limit: Shared kernels or administrative infrastructure may retain common failure paths; a container is not automatically a strong hostile-code boundary.

Related controls: SUP-05, TEST-04, GOV-02

[CSA-CCM / Cloud Controls Matrix and CAIQ v4.1](#)

[JOINT-AGENTIC / Careful adoption of agentic AI services](#)

AI024 / Verify artifact identity before use

Proposed control; effectiveness has not been verified.

How it helps: Require reviewed artifact provenance plus a digest or signature checked against an independently trusted identity or manifest.

Evidence to obtain: Substitute bytes, producer identity, or verification metadata in a controlled test and confirm the consumer rejects the artifact.

Remaining limit: Authenticity establishes the producer and bytes; an approved producer can still ship vulnerable or malicious content.

Related controls: SUP-03, DATA-04

[OPENSSF-MODEL-SIGNING / Launch of Model Signing v1.0](#)

[SLSA-12 / Supply-chain Levels for Software Artifacts specification](#)

AI024 / Keep pinned artifacts maintained

Proposed control; effectiveness has not been verified.

How it helps: Review known-vulnerability and maintenance evidence for the actual resolved artifacts and apply updates through a repeatable release process.

Evidence to obtain: Demonstrate a dependency update, relevant regression checks, and deployment or rollback of the resulting approved artifact.

Remaining limit: This source/image scan does not provide a current CVE verdict, and a vulnerability database cannot identify every unknown flaw.

Related controls: SUP-02, SUP-04, OPS-05

[NIST-SSDF / Secure Software Development Framework \(SSDF\) Version 1.1](#)

[OPENSSF-SCORECARD / OpenSSF Scorecard](#)

AI002 / Enforce action policy outside the model

Proposed control; effectiveness has not been verified.

How it helps: Have an execution service allow only named operations, permitted argument values, and caller-owned target resources before invoking a tool.

Evidence to obtain: Exercise disallowed operations, additional arguments, cross-tenant identifiers, and direct calls that bypass the agent planner.

Remaining limit: Authorized operations can still be harmful when business constraints are incomplete; prompt instructions cannot enforce this boundary.

Related controls: AGT-01, AUTH-02, MCP-02

[MCP-TOOLS / MCP: Tools](#)

[OWASP-AGENT-CS / AI Agent Security Cheat Sheet](#)



AI002 / Isolate tool execution

Proposed control; effectiveness has not been verified.

How it helps: Run the risky tool in a separate, disposable identity with no host mounts, ambient credentials, or unnecessary outbound access.

Evidence to obtain: In a test environment, attempt reads outside the workspace, forbidden network connections, and resource exhaustion; retain policy and denial evidence.

Remaining limit: Isolation limits reachable assets; it does not make injected code trustworthy or rule out a runtime escape.

Related controls: EXEC-02, SUP-05, OPS-02

[JOINT-DEPLOY / Deploying AI Systems Securely: Best Practices for Deploying Secure and Resilient AI Systems](#)



Coverage gaps and required validation

No operational gap was recorded within the selected scope. Unsupported runtime properties still require their own checks.



Interactive review workspace

Every bound item below remains tied to its original evidence. Blank means unreviewed. Any nonblank decision requires a reason; justified/disabled also require a reviewer. Coverage gaps cannot be justified or disabled. Runtime/human decisions identify outstanding validation and are not passes.

Long fields scroll in compatible PDF viewers. Save with regenerated appearances. If your editor flattens the form or cannot preserve it, use the JSON review workspace instead.

finding:979d192981c1785a2394fe19

finding

AI002 Dynamic command executed through a shell - agent.py:9

Evidence binding: 27773d89a46b65e9641fec94b2f774439316eb1e2a72ee0a43990d4dd85ea213

DECISION

justified

REVIEWER

Invarune workflow test

REASON / JUSTIFICATION

TEST ONLY: deliberate inert fixture retained for scanner regression. This assertion validates no production safeguard.

REVIEWED AT (YOUR DATE)

2026-09-19

EVIDENCE REFERENCE

scripts/validate_report_review.py

finding:0fa7e450cd583d78646ef397

finding

AI003 Dynamic os shell command - agent.py:10

Evidence binding: 2675419f39b2ce5cab37dd11da0600ef6d5edf652c6207fc4d7d4cf2f0765a6d

DECISION

Unreviewed

REVIEWER

REASON / JUSTIFICATION

REVIEWED AT (YOUR DATE)

EVIDENCE REFERENCE

**finding:07fc5f6fd7699fd0194dc479**

finding

AI006 TLS certificate verification disabled - agent.py:11

Evidence binding: 586fe34091e0168ab26769438bc6fc5cbd9ced23112ba3420fdae957a79ac64f

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****finding:d2d09fb2875db72f18779bfc**

finding

AI005 Executable deserialization requires trusted inputs - agent.py:12

Evidence binding: f68a720f121f92b2838e037eea6a4f09ad2fe9a4a225b8a80d572bf8e0552229

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**finding:b1b0f0a3f33fe93875fcb58a**

finding

AI001 Dynamic Python code execution - agent.py:16

Evidence binding: c96fa8cb643a27da7c8cdddf5c892896d5b08268b4118e485ecdd633b54bea99

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****finding:afb2bdb94696690028650faf**

finding

AI010 Credential-like literal in source or configuration - mcp.json:6

Evidence binding: dabdb736f3d6815b982eeacc75e98c53320b22840b3a696e8b2a354d537a0993

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**finding:592fbfc9b7dab062dc97906c**

finding

AI031 Agent approval or sandbox safeguard explicitly bypassed - mcp.json:7

Evidence binding: 1ec9d3989ddff79d71c4d731cbc35e33ea99212e251fbfb2d733cd948bfd6c2e

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****finding:d841174f55e032505f8136b9**

finding

AI029 Remote MCP URL uses plaintext HTTP - mcp.json:10

Evidence binding: c9d6f72864ebcfd443c63a65b21e6424bda7147f0d984819bb21a351e5738841

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**finding:20771a324af20de316ec34f9**

finding

AI021 Container explicitly runs as root - Dockerfile:2

Evidence binding: 87ba49d5b7f358d988d6227891b1eea94c831ae2bb9cdae20b4fe51e2a97fe38

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****finding:6b77081a826c4c6833edc47f**

finding

AI018 MCP package runner resolves an unpinned artifact - mcp.json:4

Evidence binding: 0d084a38b6b3114ff50bf741cff357b1f12327d931fe63e8517eae3defa80a63

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**



finding:055ed29e5f56926f1827a0b8

finding

AI024 Container image is not digest pinned - Dockerfile:1

Evidence binding: d6aa2fcd1da8f0395ddf746c9c8a69e11af6890b3d5437337fac5f15e4500be2

DECISION

Unreviewed

REVIEWER

REASON / JUSTIFICATION

REVIEWED AT (YOUR DATE)

EVIDENCE REFERENCE

check:GOV-01:1

check

GOV-01:1 Record owner, deployment, model/version, MCP transport/version, exposed tools, data classes, and external endpoints.

Evidence binding: 44633a08ec4cc1979bd1ba1b366c8a2ca42c950fc2ded0a32a2a94729bbd6df2

DECISION

justified

REVIEWER

Invarune workflow test

REASON / JUSTIFICATION

TEST ONLY: deliberate inert fixture retained for scanner regression. This assertion validates no production safeguard.

REVIEWED AT (YOUR DATE)

2026-09-19

EVIDENCE REFERENCE

scripts/validate_report_review.py

**check:GOV-01:2**

check

GOV-01:2 Reconcile approved inventory with deployed configurations; investigate unregistered agents and servers.

Evidence binding: 75f8726f331fa515fbef38127dfaaf784f54cfbd1c30dff1275ead2b25e990bd

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:GOV-02:1**

check

GOV-02:1 Diagram user, model, memory, tool, server, gateway, and downstream service boundaries with their credentials.

Evidence binding: b75843ed0dfacb0777032f43d4bd78dfca7b73be245c55a42dfb1c85d8fd7cc3

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:GOV-02:2**

check

GOV-02:2 Identify who controls each input and the highest-impact action reachable if that input is malicious.

Evidence binding: 3197526f39f2704a451bf94e0654a45d849cfddd1c5af6a4c93f1868e24bceab

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:GOV-03:1**

check

GOV-03:1 Assign an owner to each autonomous action and document permitted purposes, forbidden outcomes, and escalation routes.

Evidence binding: be27ecfed4547df8133a242a2752c819f79c90f45740dd36ce9adc72c4da6ec8

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:GOV-03:2**

check

GOV-03:2 Record impact, reversibility, approval requirements, and accepted residual risk before production use.

Evidence binding: 567af5e90d5de86a111dd5e53fa4e11dd3c9b20a539755d52f5c5baea7af8b27

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:GOV-04:1**

check

GOV-04:1 Give each control an owner, evidence link, validation date, result, and next review date.

Evidence binding: 8b593d71babd0c1bc5ebf5cb17dc221e89350dad2e565526081dbc556b89bd7e

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:GOV-04:2**

check

GOV-04:2 Time-limit exceptions and require a compensating control; distinguish untested behavior from demonstrated failure.

Evidence binding: 160d9e2eb980eb08f39475e4cd2c363536f52c7d9f8b2be835cfded63c6ad4da

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:GOV-05:1**

check

GOV-05:1 Review security impact when adding a model, tool, server, data source, skill, or broader permission.

Evidence binding: 2a308b7f87ce8e2c517631743ac8c0a8859fc49b47ca3192c2355c2f001316a5

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:GOV-05:2**

check

GOV-05:2 Require deployment evidence for the complete configured system; a model-only score is insufficient.

Evidence binding: 98ab6b21d366cf70a334491cb914b9778d7b063ad95cbb998e258d307e5ace6a

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:GOV-06:1**

check

GOV-06:1 For each model, gateway, orchestrator, MCP service, and cloud provider, document which party implements each applicable safeguard and which customer configuration it depends on.

Evidence binding: 0577b3b621422027202f848f270b3459de9e9ed8bfb56f3f46ece93c760fa19d

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:GOV-06:2**

check

GOV-06:2 Obtain current supplier evidence for inherited safeguards, identify unowned gaps, and record reassessment triggers in the service review.

Evidence binding: 85fca2bb61781bcc0e2e03e89e5c52f4f0f922974c4811abdf20be3a4d481d93

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:AUTH-01:1**

check

AUTH-01:1 Trace authentication to every protected HTTP entry point, including tool calls, subscriptions, and retries.

Evidence binding: 2414d475dea63be40b6dee1eecb2bb8fa31467af2e716d2e1b900cd40d63fc2

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:AUTH-01:2**

check

AUTH-01:2 Verify missing, expired, revoked, or malformed credentials cannot invoke a protected operation.

Evidence binding: d8c330c0549115b7c329d9d889373a5a543998bb610f57ee1387ea6c8110129f

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:AUTH-02:1**

check

AUTH-02:1 Check user/agent identity, tenant, tool, target object, and requested operation immediately before execution.

Evidence binding: 12021b97fb299b7c4256e55512a76debee227c18d5975aaafea89d5cb1ec6049

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:AUTH-02:2**

check

AUTH-02:2 Deny by default; test read-only callers against write tools and object identifiers owned by another user.

Evidence binding: 8acc7499f261b0ca7897cb4724eacc0100857a3058eb9c9273a59c97a3a89f07

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:AUTH-03:1**

check

AUTH-03:1 Verify signature with trusted keys, allowed algorithms, expected issuer/audience, expiry, and required scopes.

Evidence binding: c4816da586ca1452002d80246522c5d5a2ae0f0643eda15df08e9383ed48d167

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:AUTH-03:2**

check

AUTH-03:2 Reject unsigned tokens and tokens minted for another service; decoding a JWT alone is not validation.

Evidence binding: 494eab3bc606c38badb0295182ed83c90e369ab8bc3bd052435fde3a72b93fd9

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:AUTH-04:1**

check

AUTH-04:1 Use audience-bound MCP credentials and separately authorized downstream credentials; never forward arbitrary caller tokens.

Evidence binding: 89d5b451f1aa2b8ea999b8e14f16a9b48fa38fc7bff1600252379d9fb88c6965

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:AUTH-04:2**

check

AUTH-04:2 Ensure a proxy cannot use its broader service identity to perform an action the caller cannot authorize.

Evidence binding: 55a7c95b2cd64691cf81625419199385d621900783f1a9b5eb09b54d2914f2b7

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:AUTH-05:1**

check

AUTH-05:1 Use short-lived scoped credentials where supported, protect refresh tokens, and validate rotation and revocation.

Evidence binding: 4f8d6bc0371ffd59277c8f3907eb24fff2e500fdf1032942dd3b28cb1b5591b8

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:AUTH-05:2**

check

AUTH-05:2 Avoid tokens in query strings, model context, source, child-process arguments, and diagnostic output.

Evidence binding: caee791123b60bd54c7bd5f867580232bec22dff334487367c76d50e7d8ee420

DECISION**REVIEWER****REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:AUTH-06:1**

check

AUTH-06:1 Test PKCE support and S256, exact registered redirects, transaction binding, and authorization-response issuer validation.

Evidence binding: 151fa5c3856fbae1eb5441ccd5b734d0c2554c2185955cafd3cd60824c6bd30

DECISION**REVIEWER****REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:AUTH-06:2**

check

AUTH-06:2 Reject replayed codes, mismatched issuers, unsafe redirect schemes, and unsolicited callback transactions.

Evidence binding: 2f4da16ebd7f451ca518ba245bcc0ba213ccc56ba4b12b6ec5a380cda5e623d7

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:AUTH-07:1**

check

AUTH-07:1 Validate discovered metadata and client metadata URLs before fetching; constrain schemes, destinations, redirects, and response sizes.

Evidence binding: 0ebc38da5cd543f1581d291a463da6b045df630f1e38958bb35876c4d30fe3f3

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:AUTH-07:2**

check

AUTH-07:2 Document trust policy for client registration and prevent discovery from reaching internal metadata or privileged network services.

Evidence binding: 311f100c1a5d8f32302ef530dd1135ce4cfcc7e80d61965e4251bd833ec813d5

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:AUTH-08:1**

check

AUTH-08:1 Carry authenticated initiator and delegation identity through multi-agent calls instead of trusting identity fields in text.

Evidence binding: 0d25bab637dab83e3ccc0a4210d1a5500447a9750d4d0120374583789a9b5393

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:AUTH-08:2**

check

AUTH-08:2 Prevent agents from granting themselves privileges; limit delegation scope, depth, lifetime, and downstream audiences.

Evidence binding: 286ca2d04c0e35d4c93f0e802003317df775973d979f6bd4c35fd6bcb4cc2716

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:AUTH-09:1**

check

AUTH-09:1 Enroll agents under an accountable sponsor and approved workload identity; verify identity claims before issuing credentials or granting discovery and execution access.

Evidence binding: 083a1c152ac145e5bd97638bed69b01a609b3cdaf3340d26148c1537063f27e5

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:AUTH-09:2**

check

AUTH-09:2 Test retirement, sponsor departure, redeployment, and identity compromise; remove stale credentials, cached grants, registrations, and downstream access.

Evidence binding: a66b7a10f368bab08549b1d8e2bc33d09b350a4a37f75679dd916586f47da8d3

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:MCP-01:1**

check

MCP-01:1 For HTTP, reject invalid Origin values and verify local deployments bind only to intended interfaces.

Evidence binding: ddde370e8134892e6b905af4e515125bb03e520243f1822de02a6691ce74ae10

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:MCP-01:2**

check

MCP-01:2 Use TLS for remote protected endpoints; test DNS rebinding and proxy/header behavior in deployment.

Evidence binding: 4c062c6588db9d2a0adde8693ebc5a63e7d42cd16cac1218880e158283fd00c0

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:MCP-02:1**

check

MCP-02:1 Apply schemas and semantic bounds before executing every tool; reject unknown properties where appropriate.

Evidence binding: 2da576478baaa722f2f35cd028ff4bbe1980c88740d634bdf6ad3f076c41237c

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:MCP-02:2**

check

MCP-02:2 Bound sizes and nesting; validate declared structured output and render errors without leaking secrets.

Evidence binding: 103ce5993b6e0f330616885480479d541ecab6f8a7dd79a7980ef486a0a9f1b8

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:MCP-03:1**

check

MCP-03:1 Inspect descriptions, schemas, resources, icons, and results for instructions that cross tool or user boundaries.

Evidence binding: 7ddffdc83805867c9e82a654d79962fd11f69598c8c18b5f54366df4665b3ad

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:MCP-03:2**

check

MCP-03:2 Never let readOnlyHint, destructiveHint, or other server claims replace independent authorization and approval policy.

Evidence binding: 6fcd0113a96032aa24ca2a45bd614f0612c4d89fc80ee1653ba5b7ec4333cdf9

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:MCP-04:1**

check

MCP-04:1 Bind tool approval to verified server identity and the reviewed tool definition or version.

Evidence binding: 40fa5b998b812b7691064f07a63fe462b14ba0501de0c9651fc50377d1ce5ee0

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:MCP-04:2**

check

MCP-04:2 Revalidate changes after reconnect/list updates; disambiguate collisions across servers without trusting display names.

Evidence binding: 2ada649e0f9e229391ec82cbbd7dc4fa742bbccd650cb5f6d7fb68bb8acc7fbf

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:MCP-05:1**

check

MCP-05:1 Authorize every state handle against its owner and tenant; enforce expiry, unpredictability, and replay boundaries.

Evidence binding: 1296118f2bb72649683d9d4543287f7845df2e155218ad5dc7bc8101d923d18e

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:MCP-05:2**

check

MCP-05:2 For older sessionful protocol versions, test session hijacking and cross-user resumption; a session ID is not authentication.

Evidence binding: c0266a504913cb600bdc59a981e9f2ce15b6bc6a33736c35bff08f860c68a0f4

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:MCP-06:1**

check

MCP-06:1 Apply host policy and user control to sampling requests, context sharing, model selection, and associated tool access.

Evidence binding: 1985dbc104822627274113a1b899073a3757b043df891591dfa8b4e789d3969e

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:MCP-06:2**

check

MCP-06:2 Test whether an untrusted server can induce disclosure from unrelated conversations or recursively consume model budget.

Evidence binding: 26c0114f8882d0dc4119b77b94a8a857c5e60c50df079b2897283e0cf6a069c2

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:MCP-07:1**

check

MCP-07:1 Keep sensitive credential collection out of form-mode elicitation; validate and visibly identify URL destinations.

Evidence binding: 0eaa23874f195d528cae1dab0deb21dcdb6a8d1ac37b10707b48c093173b6db7

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:MCP-07:2**

check

MCP-07:2 Test cancellation, phishing URLs, unsolicited interactions, and replayed completion state against the selected protocol version.

Evidence binding: b17566f581a2e1ebee1a2f26967efdc3f5a3b349ed15f85cff7002d486523fce

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:MCP-08:1**

check

MCP-08:1 Treat declared roots as scoped information, not an operating-system sandbox or complete authorization mechanism.

Evidence binding: 0796cbfb9be38fde5b4bc52c8720247431d30a701369cc6e50ffecb0040efe51

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:MCP-08:2**

check

MCP-08:2 Enforce allowed paths at file access and test traversal, symlinks, alternate encodings, and writes outside the workspace.

Evidence binding: 71f8b438441c786617cabd2948623e9d69e0ddc185a6714533db01b8e174ca73

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:MCP-09:1**

check

MCP-09:1 Approve executable and package identity before starting a stdio server; use argument arrays and a minimal environment.

Evidence binding: ed4440f75215debfcbe1044f73ce34bbd0d5cdd26c6efaf4fec0cd0e2bcec5d

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:MCP-09:2**

check

MCP-09:2 Restrict proxy process-spawn APIs and child filesystem/network permissions; separate stdout protocol traffic from logs.

Evidence binding: 70887d8f58eec6cf9697043880123efb2b0faac2b38b347b0c69c218daf88de7

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:MCP-10:1**

check

MCP-10:1 Record supported revisions and test their capability, metadata, header consistency, stream, and cancellation rules.

Evidence binding: c8f1c36fa8df26b4b89d42b19a714669a599a844107d8b35281788cb2e04d6e8

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:MCP-10:2**

check

MCP-10:2 Prevent caches and request continuations from crossing authorization contexts; do not apply legacy handshake assumptions universally.

Evidence binding: fa47938c8a1c69e0252c0809aa18af0ed2d5ded471d2b72f399a3548b8bf50da

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:AGT-01:1**

check

AGT-01:1 Place allow/deny decisions at the execution boundary using trusted policy inputs and constrained tool capabilities.

Evidence binding: 4732d4211678a253909c263357d41abd865ec41a04410c45dbdc82a6de5b9575

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:AGT-01:2**

check

AGT-01:2 Show that an injected instruction cannot disable policy, choose privileged credentials, or bypass approval.

Evidence binding: 7e6aa88f66c6955c3404928578dd46ebd1efbb2f462be7978782f20e4eaa1f66

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:AGT-02:1**

check

AGT-02:1 Present actual recipient, target, arguments, data disclosure, and consequences for high-impact approval.

Evidence binding: bc745884f07088c692fca03781b9ccc0b5b8ecb3afb568109a7a1596efa84d77

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:AGT-02:2**

check

AGT-02:2 Invalidate approval if arguments or target change; test races, delayed retries, and approval reuse.

Evidence binding: 3dc5fe50eb99e786892c33fa00d0b7e4461874bec9b10e0d9768554a7bdeecb7

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:AGT-03:1**

check

AGT-03:1 Track origin and trust level for web pages, documents, messages, OCR, tool results, and repository instructions.

Evidence binding: c7d224678be65030f5eabd3381490df995c209081d55dc8faa363070fb6a2304

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:AGT-03:2**

check

AGT-03:2 Test direct and indirect goal hijacking; formatting delimiters and prompt warnings alone are not access controls.

Evidence binding: a444f0e5d06010a8166e07d0d04b7318e6a2b1d2de848144f6ac51889bd4cf65

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:AGT-04:1**

check

AGT-04:1 Enforce document and memory ACLs at retrieval and update time, including vector search metadata filters.

Evidence binding: 28b9592612298bfb99d9fa95300d30993efc318606b17752e3e36f31b4d3f7e0

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:AGT-04:2**

check

AGT-04:2 Test poisoned memory persistence, cross-tenant retrieval, provenance loss, deletion, and stale privileged context.

Evidence binding: 0375f59f17326db90bed75ee9f798a2c7471f40c46cb14db014a141fe6d7c289

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:AGT-05:1**

check

AGT-05:1 Constrain delegated tasks and verify messages against authenticated senders, expected schemas, and allowed transitions.

Evidence binding: 10a7379e0893cea7397418a4fa16670158abacb866c316dc8a963daf4f355233

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**



check:AGT-05:2

check

AGT-05:2 Test impersonation, conflicting instructions, cascading failure, and privilege growth across handoffs.

Evidence binding: d694b1f3c1370c893d15d292fa6891c8494ab469224d1bffb8e62a8d038a56a

DECISION

Unreviewed

REVIEWER

REASON / JUSTIFICATION

REVIEWED AT (YOUR DATE)

EVIDENCE REFERENCE

check:AGT-06:1

check

AGT-06:1 Inventory skill files, prompts, hooks, memory seed files, MCP configuration, and other executable workflow inputs.

Evidence binding: 429faa12a851d7a1b36fedc5cebf6f87a6afb3b22387feb1ef9ff042b9b50998

DECISION

Unreviewed

REVIEWER

REASON / JUSTIFICATION

REVIEWED AT (YOUR DATE)

EVIDENCE REFERENCE

**check:AGT-06:2**

check

AGT-06:2 Require review for changes that add commands, access, or persistence; external repository text cannot become trusted policy.

Evidence binding: dbb6dd39de2c829ecd670947f9db022d6ad1115ef89bd1ad6533f5458de84da8

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:AGT-07:1**

check

AGT-07:1 Apply destination and data policies to URLs, searches, tickets, messages, uploads, and telemetry generated by agents.

Evidence binding: 5b3d7229c2193b15f52a22fe9ec59207ec2a8b1642298064a72d3ab37c5e334a

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:AGT-07:2**

check

AGT-07:2 Use canary data to test encoded leakage and combinations of otherwise permitted tools.

Evidence binding: 6c5f0e80e7380970d3472de357cd7b8f6cae54416a47d8c1b836e9b6100ce70c

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:EXEC-01:1**

check

EXEC-01:1 Find shell execution and constructed command strings; use fixed executables, argument arrays, and allowed argument values.

Evidence binding: 0594464e355ca6be1b30508428eb88428e74e30c02e8f5cde5803e1f68c74ada

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:EXEC-01:2**

check

EXEC-01:2 Test untrusted tool inputs containing shell syntax, option injection, command substitution, and hostile filenames.

Evidence binding: fb31ad5ebf3f506d81ded7c3abc410ab0cdc554248aec430374059633c4a5973

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:EXEC-02:1**

check

EXEC-02:1 Locate eval, exec, dynamic imports, templates, notebooks, and interpreter tools accepting model or user content.

Evidence binding: eade4871b35062e966f58e9980bb21260d49513486c72257f62c590328353ca0

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:EXEC-02:2**

check

EXEC-02:2 Run required code execution in a disposable restricted environment with explicit filesystem, network, CPU, and time limits.

Evidence binding: 95b20ba717af77676220391c5e931dd50d3bcd99c1d322918f90191e76c7a53

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:EXEC-03:1**

check

EXEC-03:1 Use bound query parameters and allowed query shapes; inspect SQL, NoSQL, graph, and search-language construction.

Evidence binding: 6c16c59b54660024b506bbf0110272f4b5f86b21f791145d502b4ed489a03dbd

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:EXEC-03:2**

check

EXEC-03:2 Separate read/write database identities and test whether generated queries can escape permitted objects or operations.

Evidence binding: de09b942269c76daa42c63c69705a47e007e292d1b59c726f392216c705f1813

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:EXEC-04:1**

check

EXEC-04:1 Resolve and enforce allowed paths at access time; constrain uploads, downloads, extraction, temporary files, and permissions.

Evidence binding: 7f05cdf56403096bc51e024bf64e76db51eea5213658104c512c6189b8b100cb

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:EXEC-04:2**

check

EXEC-04:2 Test symlink races, archive traversal, absolute paths, overwrite attempts, and secret-directory reads.

Evidence binding: 07d288cce74dfaf62280cb0222ae12258c60cf277ead45c232df82e04102f245

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:EXEC-05:1**

check

EXEC-05:1 Restrict destinations and schemes at connection time; revalidate DNS resolution and each redirect.

Evidence binding: fd4c0b9329366fb165aaf2a8b32d130afdf9e7d714b91ce013fd0e4df733c64e

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:EXEC-05:2**

check

EXEC-05:2 Test loopback, private/link-local IPv4 and IPv6, cloud metadata, alternate encodings, and redirect-to-private cases.

Evidence binding: 2c18754eaa6b71c8473d42cd8419c9d99ba50e7cb47425b2bcabb6101f480ea7

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:EXEC-06:1**

check

EXEC-06:1 Inspect pickle, unsafe YAML, object deserialization, XML entity expansion, and unconstrained recursive parsers.

Evidence binding: 540de215cb2d61ae0bd883a2ff83b214611bdbe608b05cbd1746a9afa0f3bbce

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:EXEC-06:2**

check

EXEC-06:2 Use data-only formats with byte, nesting, and type limits; test malformed input and expansion attacks.

Evidence binding: bcc95153e5d3089fff95c4d8651887b1ae4d7b484f7f5213fa2cd08683b7693d

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:EXEC-07:1**

check

EXEC-07:1 Use context-specific escaping for HTML/Markdown, avoid unsafe DOM sinks, and validate links and embedded media.

Evidence binding: f1a4080945e4cc81fa69773cccd0a2a34f182803fc30aeb10fc875292db2d2a

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:EXEC-07:2**

check

EXEC-07:2 Test active SVG/HTML, malicious URLs, terminal escapes, and spreadsheet formulas in exported reports.

Evidence binding: 2120d7ed824733450bc931982074dfae9fc5732973597cae8d27c991290fd26c

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:DATA-01:1**

check

DATA-01:1 Inspect code, examples, configuration, notebooks, test fixtures, and generated artifacts for secret-like values.

Evidence binding: cb5963706d5883c636a5ea7b1401e7b20d1a9bc7826f5b966e375d6e6b282b71

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:DATA-01:2**

check

DATA-01:2 Verify actual exposures with the owner, rotate real credentials, and remove them from reachable history and artifacts.

Evidence binding: f79a577ce1f3c12b216b1caf4064583c5abd82a2fd22cca5ca32cb1f306f9968

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:DATA-02:1**

check

DATA-02:1 Map which prompts, tool outputs, memory, and code leave the environment and identify the receiving provider/gateway.

Evidence binding: 6456d7d10dc0f0db2e78a34a398bebc303f3e1754d6c619c6e105c29a126b725

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:DATA-02:2**

check

DATA-02:2 Document allowed data classes, processing location, retention, and training use; redact before transmission where required.

Evidence binding: 2ad720afd98431432dc6961c20f905867c8e49a0f2383c58c7c8f4481570f6d6

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:DATA-03:1**

check

DATA-03:1 Redact secrets and sensitive payloads before logs, traces, exception strings, and dashboards persist them.

Evidence binding: b20a605a196abc0399b64505bd957f955b7817c31bd7efc9a406a1f334ed88b4

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:DATA-03:2**

check

DATA-03:2 Test the failure paths and provider errors as well as success paths; restrict access and export destinations.

Evidence binding: 0f6eb089e0badb7e1673786490372058d1d8c664aed9f8fd39df59f3b139f345

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:DATA-04:1**

check

DATA-04:1 Record source, owner, version, transformation history, and integrity evidence for datasets, retrieval corpora, and memory seeds.

Evidence binding: 2bef65878c15baae37bda42431addf61c1ff3e1015af275843fcf43b041aaa85

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:DATA-04:2**

check

DATA-04:2 Quarantine unexpected changes and test how poisoned or stale data is detected, removed, and replaced.

Evidence binding: 20040bb0cd558bbcde074e4153952522c3c24d7bee65b87c9574a8b1698c36c9

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:DATA-05:1**

check

DATA-05:1 Apply expiry and deletion to prompts, embeddings, caches, memory, tool artifacts, backups, and provider-held data.

Evidence binding: a4f06c5405c2d777118d8cfccb83d329cfbd36bbe8acf9f5bad59bf780581847

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:DATA-05:2**

check

DATA-05:2 Verify deleting a source record removes or invalidates dependent retrieval content and access grants.

Evidence binding: 3a77e358954ed29ea102643643733bbc4e3eb4d50d0c117b094f742b3605d40a

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:DATA-06:1**

check

DATA-06:1 Check transport verification, storage access controls, encryption settings, key separation, and backup permissions.

Evidence binding: f7fe68a7560a3c128caf9d6f658b1b838142a9ea2fda3079e38a1328e2cd50e9

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**



check:DATA-06:2

check

DATA-06:2 Validate key rotation and denied access using a principal outside the authorized tenant or operational role.

Evidence binding: bf85c358a63e71df91fcd3284502bbf7e07b6af5e69f1f3bf12411199381db98

DECISION

Unreviewed

REVIEWER

REASON / JUSTIFICATION

REVIEWED AT (YOUR DATE)

EVIDENCE REFERENCE

check:SUP-01:1

check

SUP-01:1 Review lockfiles and exact versions or immutable digests for packages, images, MCP servers, models, and plugins.

Evidence binding: ef15edbbba549aec81314935fb61ab8c353ae7a88d3449b3f79c9e69beebd3fb0

DECISION

Unreviewed

REVIEWER

REASON / JUSTIFICATION

REVIEWED AT (YOUR DATE)

EVIDENCE REFERENCE

**check:SUP-01:2**

check

SUP-01:2 Flag runtime installs, floating tags, remote scripts, and dependency sources outside approved registries.

Evidence binding: a5ce26648950cc21b5623e2a14463e49aa8a75be03a65f576a561618fa8c0ef0

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:SUP-02:1**

check

SUP-02:1 Run appropriate package/container advisory tools against resolved dependencies and save database date and tool version.

Evidence binding: e6886c0ee6c974e523f61afc96f6aec0c6428a1d0b81f57cd58205268ac7134

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:SUP-02:2**

check

SUP-02:2 Triage reachability, fix availability, support status, and transitive dependencies; source pattern scans do not establish CVE coverage.

Evidence binding: cf04470aba76d62ac0f7b0dd4d912771f202ce2dfbccaabb0cdfcaa5bdeac45e

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:SUP-03:1**

check

SUP-03:1 Verify publisher identity, hashes/signatures, build provenance, and intended origin before enabling artifacts.

Evidence binding: cbae4a923ca017fd0a64945a2aaf13b589d03c61639fbbe8e5ba7696a5cc03b4

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:SUP-03:2**

check

SUP-03:2 Review model loading and serialization behavior; an integrity hash cannot make an untrusted publisher safe.

Evidence binding: 2da788da234616249994d1ce7cffba753d0a1c7a11ddb77bb2ccbf30f3339548

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:SUP-04:1**

check

SUP-04:1 Restrict CI credentials and workflow permissions; review actions, build scripts, and release provenance.

Evidence binding: b9c32510b04d74b494fdda20550c33310a64583b9ffc0c31c822964714f068a6

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:SUP-04:2**

check

SUP-04:2 Prevent untrusted contributions from executing with deployment secrets or changing approved agent policies.

Evidence binding: 5f62187c40c989d4e4b971c1d382032abe99258bb22799f4da423c0e767c9f7c

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:SUP-05:1**

check

SUP-05:1 Review root/privileged containers, host mounts, Docker sockets, unrestricted egress, debug mode, and public management endpoints.

Evidence binding: 45ec530d8f30a7bec4e08a68075b2f2c1992e6cf3bc7496ba17a6074560c2240

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:SUP-05:2**

check

SUP-05:2 Separate agent execution from control-plane credentials and audit storage; test isolation in the deployed environment.

Evidence binding: 36af5f6b3a5ab2cae674e4035791f5b8d4128b677d71a710607fc78790cae4fc

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:SUP-06:1**

check

SUP-06:1 When training or fine-tuning, isolate development, evaluation, and production identities, data access, registries, and release permissions.

Evidence binding: 8249aecbd15c947ba5973fa2ac64054c6b51505176b751872ebcdd4487759e21

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:SUP-06:2**

check

SUP-06:2 Protect datasets, weights, adapters, and configuration separately; monitor modifications and demonstrate that an untrusted training job cannot replace an approved production artifact.

Evidence binding: 691197dedd1e13fa7c9c06e6051f72b4ec1faa690d9c5c621558bd53a3db5b02

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:OPS-01:1**

check

OPS-01:1 Record initiating identity, delegated identity, tool/server/version, approved arguments, decision, outcome, and correlation identifiers.

Evidence binding: 41cb9ee2a4d79fcf2cb75b454c08ef8e8e28756b054abc9c1f93426461d8f0b

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:OPS-01:2**

check

OPS-01:2 Protect log integrity and clock consistency; ensure agents cannot erase their own action history.

Evidence binding: b87f139beab6530792905738073b2d3da070713046a1542070f926b56aaa1843

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:OPS-02:1**

check

OPS-02:1 Set server-enforced limits for iterations, tokens, tool calls, recursion, parallelism, bytes, cost, and elapsed time.

Evidence binding: ce9e4386eca2d0302c9b1ad13cfc773787b50719ebe391b2da2e35708ddf2c3f

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:OPS-02:2**

check

OPS-02:2 Exercise stuck loops and amplification paths; verify limits apply across retries and child agents.

Evidence binding: 2bcc89ce855a177494253561de5759e29a1d85b8d8f93090239ae5c5f9502aba

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:OPS-03:1**

check

OPS-03:1 Provide a tested stop mechanism that revokes work, credentials, queued actions, and child tasks.

Evidence binding: 461db73455b383192eb60f338675d88fd7b1dec42bf6fc304294cf2f5a930fc7

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:OPS-03:2**

check

OPS-03:2 Measure stop latency and verify cancelled or disconnected requests cannot later commit prohibited side effects.

Evidence binding: 5d4c873dc8b857fec016cf8aa12b932cc6848b2bd5739e5ed4fab1c975f1c6ab

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:OPS-04:1**

check

OPS-04:1 Deny or escalate when policy, identity, or approval checks fail; prevent fallback paths from widening privilege.

Evidence binding: 02c219cf6ba9bba4669fe9a8d86ad4e7ab37ded27f670c8a8cae94c11d8cf7e0

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:OPS-04:2**

check

OPS-04:2 Test outages, partial failures, timeouts, retries, idempotency, and recovery of transactions with external effects.

Evidence binding: f4e46e38dc91fb444482f63f677895ac2ec87c689d38af3239ec25f9a14f605a

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:OPS-05:1**

check

OPS-05:1 Alert on unusual tool use, new destinations, scope growth, repeated denials, cost spikes, and unexpected state changes.

Evidence binding: 0a8fd5ab407c01a8e9303a542a3f990ad613da0c0bd4d106d7a67115becbcfdb

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:OPS-05:2**

check

OPS-05:2 Validate alerts with seeded events and test rollback of models, prompts, tools, policies, and poisoned memory.

Evidence binding: f8f3338d02746ff2711ef0edd37de5fea5151a7f88117cbb54aabc3f596af77

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:OPS-06:1**

check

OPS-06:1 Maintain procedures to isolate agents, revoke credentials, preserve evidence, notify owners, and recover trusted state.

Evidence binding: ee2ab67536b418c5026b8be07e00e7e2b016787a1905716bcccf6a1b631780a1

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:OPS-06:2**

check

OPS-06:2 Exercise an AI-specific incident and define approved vulnerability/intelligence-sharing channels without exposing sensitive evidence.

Evidence binding: 05f60c6c721f24d02c003751aabbba34b5f05133e8dc42ec6b61aadf62499f34a

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:TEST-01:1**

check

TEST-01:1 Run paired benign and adversarial workflows with representative tools and attacker-controlled external content.

Evidence binding: 08373e9ed4cca24eb61b24a8ee64be2b121d1f39914e7ef5872c42caeabc309f8

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:TEST-01:2**

check

TEST-01:2 Record attacker success, authorized task success, blocked benign actions, and the observed unauthorized side effect.

Evidence binding: c4ca39edc2eb412d84046f7ce625be1ac20bea66d79a6ea8e9cf4d246edbc25b

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:TEST-02:1**

check

TEST-02:1 Vary payload wording, placement, modality, attacker knowledge, and attempts; rerun after changing defenses.

Evidence binding: cc66b4dd6fa810a757f892fc9eabb91babb11df2aa7ee0823d96e085a6bd6f49

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:TEST-02:2**

check

TEST-02:2 Report per-scenario outcomes, sample counts, attack budget, uncertainty, and model/harness versions instead of only an average.

Evidence binding: d5f3abbb58d55f2437aa3cdcc626e49e53652aac6d9470052f6d1de8e11a10a5

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:TEST-03:1**

check

TEST-03:1 In an isolated test environment, exercise invalid tokens, wrong audiences, origin abuse, malicious servers, and protocol fuzzing.

Evidence binding: 085bdf01f848d625ab4ab3c098662c3219783199da1f4206ac5620dc1bd58050

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:TEST-03:2**

check

TEST-03:2 Adapt scenarios to the deployed MCP revision and transports; preserve request/response evidence with secrets removed.

Evidence binding: 6feddc95a77a8f9e527acca04b32502ccea558f2f918924fa1b1ad91c2a0842e

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:TEST-04:1**

check

TEST-04:1 Create two principals and attempt cross-access to objects, memory, caches, handles, subscriptions, and execution results.

Evidence binding: 7aa3213c327856c335fafd368726535fa8f3c85d1d8392044fefca088f5a6b36

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:TEST-04:2**

check

TEST-04:2 Repeat after reconnect, delegation, failed authentication, concurrent requests, and privilege revocation.

Evidence binding: ad659c510a18efa402909db087b73c1d139841b0052a684b9d1c06c3f459e51b

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:TEST-05:1**

check

TEST-05:1 Use explicit forbidden-action canaries to verify enforcement survives hostile content, tool substitution, and delayed execution.

Evidence binding: 79b98c83be35d4c25bd518cc866306034f6a29fc0694b433f69d16e06628eda6

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:TEST-05:2**

check

TEST-05:2 Confirm paths through retries, fallback models, alternate tools, and child agents enforce the same boundary.

Evidence binding: ba43dce43564cb3fdc85868323f698fd5531e4928c22492dd7b649342d290321

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:TEST-06:1**

check

TEST-06:1 Run language-aware SAST, dependency review, secret scanning, and authorized integration tests for exposed services.

Evidence binding: 1b79cff1d7e05fc480c4a16e9a3b53f69405ac0bdeab53251bf7ee485fc3def3

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:TEST-06:2**

check

TEST-06:2 Exercise reachable injection, XSS, SSRF, path traversal, deserialization, and access-control risks with safe fixtures.

Evidence binding: e3bd3d4f6bd80cfe065c55b881a03caeb5b7cafb9ed1646cdd7a1f3c374362d1

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:TEST-07:1**

check

TEST-07:1 Simulate oversized messages, slow peers, streaming floods, repeated errors, runaway agents, and unavailable dependencies.

Evidence binding: 90d1838cc54a0fe5b66f8ff2421ea5a07a7aa56aaaaf63320efbbf83f9506569

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:TEST-07:2**

check

TEST-07:2 Verify quotas, shutdown, telemetry, and alerts work together without leaking payloads or losing attribution.

Evidence binding: 4203310080f7880fdc69ad0cdd641617c279f8158d5d75671b6fb6ee337a6095

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:TEST-08:1**

check

TEST-08:1 Treat repository text and model verdicts as untrusted; test prompt injection, fabricated locations, invalid JSON, and timeouts.

Evidence binding: a35b4b19c909e94047c657198b948fe42879d8d5a3f07e0d8488ca2539629760

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:TEST-08:2**

check

TEST-08:2 Compare against labeled cases, retain deterministic results, document model variability, and never equate a judge approval with control validation.

Evidence binding: cdfc5ebee1b9be68a5bf27a67724d661fc7b4b6f24dea9ee9f5e4a5a6a694add

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:TEST-09:1**

check

TEST-09:1 Where applicable, assess suspicious triggers, model extraction, and disclosure of private training examples under an explicit attacker access and query budget.

Evidence binding: 35777ee99a28a617e3839a8ec0a16e80fac4b3bd6e1d7e36dc5be4bb9d869ab8

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**



check:TEST-09:2

check

TEST-09:2 Retest acquired or retrained models and adapters before release; document measured failures, model identity, coverage limits, and accepted residual risk.

Evidence binding: ab42ff151c1addbb8583482da1192a329816213a6a634007bafa36d2b7ec69e3

DECISION

Unreviewed

REVIEWER

REASON / JUSTIFICATION

REVIEWED AT (YOUR DATE)

EVIDENCE REFERENCE



Control checklist and evidence requirements

GOV-01 / Inventory every agent, MCP server, tool, and model

Scanner status: manual_review_required | validation: manual

1. Record owner, deployment, model/version, MCP transport/version, exposed tools, data classes, and external endpoints.

Human disposition: justified | Reason: TEST ONLY: deliberate inert fixture retained for scanner regression. This assertion validates no production safeguard.

2. Reconcile approved inventory with deployed configurations; investigate unregistered agents and servers.

<https://www.nist.gov/publications/artificial-intelligence-risk-management-framework-ai-rmf-10>

GOV-02 / Model trust boundaries and attack paths

Scanner status: manual_review_required | validation: manual

1. Diagram user, model, memory, tool, server, gateway, and downstream service boundaries with their credentials.
2. Identify who controls each input and the highest-impact action reachable if that input is malicious.

<https://github.com/mitre-atlas/atlas-data>

<https://csrc.nist.gov/pubs/ai/100/2/e2025/final>

GOV-03 / Define authorized use and accountable owners

Scanner status: manual_review_required | validation: manual

1. Assign an owner to each autonomous action and document permitted purposes, forbidden outcomes, and escalation routes.
2. Record impact, reversibility, approval requirements, and accepted residual risk before production use.

<https://www.nist.gov/publications/artificial-intelligence-risk-management-framework-ai-rmf-10>

<https://www.cyber.gov.au/business-government/secure-design/artificial-intelligence/careful-adoption-o...>

GOV-04 / Maintain evidence and risk exceptions

Scanner status: manual_review_required | validation: manual

1. Give each control an owner, evidence link, validation date, result, and next review date.
2. Time-limit exceptions and require a compensating control; distinguish untested behavior from demonstrated failure.

<https://nvlpubs.nist.gov/nistpubs/ai/NIST.AI.600-1.pdf>

<https://csrc.nist.gov/pubs/sp/800/218/final>

GOV-05 / Reassess changes in autonomy and integrations

Scanner status: manual_review_required | validation: manual

1. Review security impact when adding a model, tool, server, data source, skill, or broader permission.
2. Require deployment evidence for the complete configured system; a model-only score is insufficient.

<https://www.ncsc.gov.uk/collection/guidelines-secure-ai-system-development>

GOV-06 / Assign shared security responsibilities across AI providers

Scanner status: manual_review_required | validation: manual

1. For each model, gateway, orchestrator, MCP service, and cloud provider, document which party implements each applicable safeguard and which customer configuration it depends on.

2. Obtain current supplier evidence for inherited safeguards, identify unowned gaps, and record reassessment triggers in the service review.

<https://cloudsecurityalliance.org/artifacts/ai-controls-matrix-v1-1>

<https://cloudsecurityalliance.org/artifacts/cloud-controls-matrix-v4-1>

AUTH-01 / Authenticate protected operations on every request

Scanner status: no_pattern_detected | validation: hybrid

1. Trace authentication to every protected HTTP entry point, including tool calls, subscriptions, and retries.
2. Verify missing, expired, revoked, or malformed credentials cannot invoke a protected operation.

<https://modelcontextprotocol.io/specification/2026-07-28/basic/authorization>



AUTH-02 / Authorize the exact action and target

Scanner status: no_pattern_detected | validation: hybrid

1. Check user/agent identity, tenant, tool, target object, and requested operation immediately before execution.
2. Deny by default; test read-only callers against write tools and object identifiers owned by another user.

<https://www.cyber.gov.au/business-government/secure-design/artificial-intelligence/careful-adoption-o...>

<https://modelcontextprotocol.io/specification/2026-07-28/server/tools>

AUTH-03 / Validate access-token cryptography and claims

Scanner status: no_pattern_detected | validation: hybrid

1. Verify signature with trusted keys, allowed algorithms, expected issuer/audience, expiry, and required scopes.
2. Reject unsigned tokens and tokens minted for another service; decoding a JWT alone is not validation.

<https://modelcontextprotocol.io/specification/2026-07-28/basic/authorization/security-considerations>

AUTH-04 / Prevent token passthrough and confused deputy use

Scanner status: no_pattern_detected | validation: hybrid

1. Use audience-bound MCP credentials and separately authorized downstream credentials; never forward arbitrary caller tokens.
2. Ensure a proxy cannot use its broader service identity to perform an action the caller cannot authorize.

<https://modelcontextprotocol.io/specification/2026-07-28/basic/authorization>

https://modelcontextprotocol.io/docs/2026-07-28/tutorials/security/security_best_practices

AUTH-05 / Constrain credential lifetime and exposure

Scanner status: findings_detected | validation: hybrid

1. Use short-lived scoped credentials where supported, protect refresh tokens, and validate rotation and revocation.
2. Avoid tokens in query strings, model context, source, child-process arguments, and diagnostic output.

<https://modelcontextprotocol.io/specification/2026-07-28/basic/authorization/security-considerations>

<https://www.cyber.gov.au/business-government/secure-design/artificial-intelligence/deploying-ai-syste...>

AUTH-06 / Bind OAuth flows and validate redirects

Scanner status: no_pattern_detected | validation: hybrid

1. Test PKCE support and S256, exact registered redirects, transaction binding, and authorization-response issuer validation.
2. Reject replayed codes, mismatched issuers, unsafe redirect schemes, and unsolicited callback transactions.

<https://modelcontextprotocol.io/specification/2026-07-28/basic/authorization/security-considerations>

<https://modelcontextprotocol.io/specification/2026-07-28/basic/authorization>

AUTH-07 / Secure OAuth discovery and registration

Scanner status: review_required | validation: hybrid

1. Validate discovered metadata and client metadata URLs before fetching; constrain schemes, destinations, redirects, and response sizes.
2. Document trust policy for client registration and prevent discovery from reaching internal metadata or privileged network services.

https://modelcontextprotocol.io/docs/2026-07-28/tutorials/security/security_best_practices

AUTH-08 / Bind delegation to identity, scope, and expiry

Scanner status: review_required | validation: hybrid

1. Carry authenticated initiator and delegation identity through multi-agent calls instead of trusting identity fields in text.
2. Prevent agents from granting themselves privileges; limit delegation scope, depth, lifetime, and downstream audiences.

https://cheatsheetseries.owasp.org/cheatsheets/AI_Agent_Security_Cheat_Sheet.html



AUTH-09 / Manage agent identity enrollment and retirement

Scanner status: runtime_validation_required | validation: dynamic

1. Enroll agents under an accountable sponsor and approved workload identity; verify identity claims before issuing credentials or granting discovery and execution access.
2. Test retirement, sponsor departure, redeployment, and identity compromise; remove stale credentials, cached grants, registrations, and downstream access.

<https://cloudsecurityalliance.org/artifacts/agent-ai-identity-and-access-management-a-new-approach>

<https://www.nccoe.nist.gov/publications/other/accelerating-adoption-software-and-ai-agent-identity-an...>

MCP-01 / Validate transport exposure and origin

Scanner status: findings_detected | validation: hybrid

1. For HTTP, reject invalid Origin values and verify local deployments bind only to intended interfaces.
2. Use TLS for remote protected endpoints; test DNS rebinding and proxy/header behavior in deployment.

<https://modelcontextprotocol.io/specification/2026-07-28/basic/transports/streamable-http>

MCP-02 / Validate tool arguments and results

Scanner status: review_required | validation: hybrid

1. Apply schemas and semantic bounds before executing every tool; reject unknown properties where appropriate.
2. Bound sizes and nesting; validate declared structured output and render errors without leaking secrets.

<https://modelcontextprotocol.io/specification/2026-07-28/server/tools>

MCP-03 / Treat descriptions and annotations as untrusted

Scanner status: review_required | validation: hybrid

1. Inspect descriptions, schemas, resources, icons, and results for instructions that cross tool or user boundaries.
2. Never let readOnlyHint, destructiveHint, or other server claims replace independent authorization and approval policy.

<https://modelcontextprotocol.io/specification/2026-07-28/server/tools>

https://cheatsheetseries.owasp.org/cheatsheets/MCP_Security_Cheat_Sheet.html

MCP-04 / Detect tool substitution and metadata changes

Scanner status: review_required | validation: hybrid

1. Bind tool approval to verified server identity and the reviewed tool definition or version.
2. Revalidate changes after reconnect/list updates; disambiguate collisions across servers without trusting display names.

<https://owasp.org/projects/mcp-top-10>

MCP-05 / Protect state handles and legacy sessions

Scanner status: no_pattern_detected | validation: dynamic

1. Authorize every state handle against its owner and tenant; enforce expiry, unpredictability, and replay boundaries.
2. For older sessionful protocol versions, test session hijacking and cross-user resumption; a session ID is not authentication.

<https://modelcontextprotocol.io/specification/2026-07-28/server/tools>

https://modelcontextprotocol.io/docs/2026-07-28/tutorials/security/security_best_practices

MCP-06 / Constrain sampling and returned model context

Scanner status: runtime_validation_required | validation: dynamic

1. Apply host policy and user control to sampling requests, context sharing, model selection, and associated tool access.
2. Test whether an untrusted server can induce disclosure from unrelated conversations or recursively consume model budget.

<https://modelcontextprotocol.io/specification/2026-07-28/client/sampling>

MCP-07 / Secure elicitation and URL interactions

Scanner status: review_required | validation: hybrid

1. Keep sensitive credential collection out of form-mode elicitation; validate and visibly identify URL destinations.
2. Test cancellation, phishing URLs, unsolicited interactions, and replayed completion state against the selected protocol version.

<https://modelcontextprotocol.io/specification/2026-07-28/client/elicitation>



MCP-08 / Enforce filesystem isolation independently of roots

Scanner status: no_pattern_detected | validation: hybrid

1. Treat declared roots as scoped information, not an operating-system sandbox or complete authorization mechanism.
2. Enforce allowed paths at file access and test traversal, symlinks, alternate encodings, and writes outside the workspace.

<https://modelcontextprotocol.io/specification/2026-07-28/client/roots>

MCP-09 / Constrain local server launch and inherited environment

Scanner status: findings_detected | validation: hybrid

1. Approve executable and package identity before starting a stdio server; use argument arrays and a minimal environment.
2. Restrict proxy process-spawn APIs and child filesystem/network permissions; separate stdout protocol traffic from logs.

https://modelcontextprotocol.io/docs/2026-07-28/tutorials/security/security_best_practices

https://cheatsheetseries.owasp.org/cheatsheets/MCP_Security_Cheat_Sheet.html

MCP-10 / Apply version-aware metadata, caching, and cancellation

Scanner status: runtime_validation_required | validation: dynamic

1. Record supported revisions and test their capability, metadata, header consistency, stream, and cancellation rules.
2. Prevent caches and request continuations from crossing authorization contexts; do not apply legacy handshake assumptions universally.

<https://modelcontextprotocol.io/specification/2026-07-28/basic/transports>

<https://modelcontextprotocol.io/specification/2026-07-28/basic/transports/streamable-http>

AGT-01 / Enforce action policy outside the model

Scanner status: findings_detected | validation: hybrid

1. Place allow/deny decisions at the execution boundary using trusted policy inputs and constrained tool capabilities.
2. Show that an injected instruction cannot disable policy, choose privileged credentials, or bypass approval.

<https://www.cyber.gov.au/business-government/secure-design/artificial-intelligence/agent-ai-harnesses>

AGT-02 / Bind approval to the action executed

Scanner status: findings_detected | validation: dynamic

1. Present actual recipient, target, arguments, data disclosure, and consequences for high-impact approval.
2. Invalidate approval if arguments or target change; test races, delayed retries, and approval reuse.

https://cheatsheetseries.owasp.org/cheatsheets/AI_Agent_Security_Cheat_Sheet.html

AGT-03 / Separate untrusted content from authoritative instructions

Scanner status: no_pattern_detected | validation: hybrid

1. Track origin and trust level for web pages, documents, messages, OCR, tool results, and repository instructions.
2. Test direct and indirect goal hijacking; formatting delimiters and prompt warnings alone are not access controls.

<https://genai.owasp.org/resource/owasp-genai-llm-top-10-2026/>

AGT-04 / Protect retrieval and persistent memory

Scanner status: review_required | validation: hybrid

1. Enforce document and memory ACLs at retrieval and update time, including vector search metadata filters.
2. Test poisoned memory persistence, cross-tenant retrieval, provenance loss, deletion, and stale privileged context.

<https://genai.owasp.org/resource/owasp-top-10-for-agent-ai-applications-for-2026/>

AGT-05 / Keep objectives and authority bounded across agents

Scanner status: runtime_validation_required | validation: dynamic

1. Constrain delegated tasks and verify messages against authenticated senders, expected schemas, and allowed transitions.
2. Test impersonation, conflicting instructions, cascading failure, and privilege growth across handoffs.

<https://genai.owasp.org/resource/owasp-top-10-for-agent-ai-applications-for-2026/>



AGT-06 / Protect agent configuration and skills

Scanner status: review_required | validation: hybrid

1. Inventory skill files, prompts, hooks, memory seed files, MCP configuration, and other executable workflow inputs.
2. Require review for changes that add commands, access, or persistence; external repository text cannot become trusted policy.

<https://github.com/mitre-atlas/atlas-data>

<https://www.ncsc.gov.uk/collection/guidelines-secure-ai-system-development>

AGT-07 / Prevent sensitive context leaving through legitimate tools

Scanner status: runtime_validation_required | validation: dynamic

1. Apply destination and data policies to URLs, searches, tickets, messages, uploads, and telemetry generated by agents.
2. Use canary data to test encoded leakage and combinations of otherwise permitted tools.

https://cheatsheetseries.owasp.org/cheatsheets/MCP_Security_Cheat_Sheet.html

EXEC-01 / Prevent shell and command injection

Scanner status: findings_detected | validation: hybrid

1. Find shell execution and constructed command strings; use fixed executables, argument arrays, and allowed argument values.
2. Test untrusted tool inputs containing shell syntax, option injection, command substitution, and hostile filenames.

<https://owasp.org/projects/mcp-top-10>

<https://genai.owasp.org/llmrisk/llm052025-improper-output-handling/>

EXEC-02 / Constrain generated-code execution

Scanner status: findings_detected | validation: hybrid

1. Locate eval, exec, dynamic imports, templates, notebooks, and interpreter tools accepting model or user content.
2. Run required code execution in a disposable restricted environment with explicit filesystem, network, CPU, and time limits.

https://cheatsheetseries.owasp.org/cheatsheets/AI_Agent_Security_Cheat_Sheet.html

EXEC-03 / Parameterize database and query operations

Scanner status: no_pattern_detected | validation: hybrid

1. Use bound query parameters and allowed query shapes; inspect SQL, NoSQL, graph, and search-language construction.
2. Separate read/write database identities and test whether generated queries can escape permitted objects or operations.

<https://genai.owasp.org/llmrisk/llm052025-improper-output-handling/>

EXEC-04 / Constrain file and archive access

Scanner status: no_pattern_detected | validation: hybrid

1. Resolve and enforce allowed paths at access time; constrain uploads, downloads, extraction, temporary files, and permissions.
2. Test symlink races, archive traversal, absolute paths, overwrite attempts, and secret-directory reads.

<https://modelcontextprotocol.io/specification/2026-07-28/client/roots>

<https://www.cyber.gov.au/business-government/secure-design/artificial-intelligence/deploying-ai-syste...>

EXEC-05 / Prevent SSRF and unsafe network destinations

Scanner status: no_pattern_detected | validation: hybrid

1. Restrict destinations and schemes at connection time; revalidate DNS resolution and each redirect.
2. Test loopback, private/link-local IPv4 and IPv6, cloud metadata, alternate encodings, and redirect-to-private cases.

https://modelcontextprotocol.io/docs/2026-07-28/tutorials/security/security_best_practices

EXEC-06 / Reject unsafe parsing and deserialization

Scanner status: findings_detected | validation: hybrid

1. Inspect pickle, unsafe YAML, object deserialization, XML entity expansion, and unconstrained recursive parsers.
2. Use data-only formats with byte, nesting, and type limits; test malformed input and expansion attacks.

<https://csrc.nist.gov/pubs/sp/800/218/final>



EXEC-07 / Render model and tool output safely

Scanner status: no_pattern_detected | validation: hybrid

1. Use context-specific escaping for HTML/Markdown, avoid unsafe DOM sinks, and validate links and embedded media.
2. Test active SVG/HTML, malicious URLs, terminal escapes, and spreadsheet formulas in exported reports.

<https://genai.owasp.org/llmrisk/llm052025-improper-output-handling/>

DATA-01 / Detect and remove embedded credentials

Scanner status: findings_detected | validation: static

1. Inspect code, examples, configuration, notebooks, test fixtures, and generated artifacts for secret-like values.
2. Verify actual exposures with the owner, rotate real credentials, and remove them from reachable history and artifacts.

<https://www.cyber.gov.au/business-government/secure-design/artificial-intelligence/deploying-ai-syste...>

DATA-02 / Minimize data sent to models and gateways

Scanner status: manual_review_required | validation: manual

1. Map which prompts, tool outputs, memory, and code leave the environment and identify the receiving provider/gateway.
2. Document allowed data classes, processing location, retention, and training use; redact before transmission where required.

<https://nvlpubs.nist.gov/nistpubs/ai/NIST.AI.600-1.pdf>

DATA-03 / Protect logs, traces, and error responses

Scanner status: no_pattern_detected | validation: hybrid

1. Redact secrets and sensitive payloads before logs, traces, exception strings, and dashboards persist them.
2. Test the failure paths and provider errors as well as success paths; restrict access and export destinations.

<https://owasp.org/projects/mcp-top-10>

DATA-04 / Track provenance and integrity of AI data

Scanner status: manual_review_required | validation: manual

1. Record source, owner, version, transformation history, and integrity evidence for datasets, retrieval corpora, and memory seeds.
2. Quarantine unexpected changes and test how poisoned or stale data is detected, removed, and replaced.

<https://www.nsa.gov/Press-Room/Press-Releases-Statements/Press-Release-View/Article/4192332/nsas-aisc...>

DATA-05 / Enforce retention and deletion across copies

Scanner status: runtime_validation_required | validation: dynamic

1. Apply expiry and deletion to prompts, embeddings, caches, memory, tool artifacts, backups, and provider-held data.
2. Verify deleting a source record removes or invalidates dependent retrieval content and access grants.

<https://nvlpubs.nist.gov/nistpubs/ai/NIST.AI.600-1.pdf>

DATA-06 / Protect stored data and keys

Scanner status: review_required | validation: hybrid

1. Check transport verification, storage access controls, encryption settings, key separation, and backup permissions.
2. Validate key rotation and denied access using a principal outside the authorized tenant or operational role.

<https://www.nsa.gov/Press-Room/Press-Releases-Statements/Press-Release-View/Article/4192332/nsas-aisc...>

<https://www.cyber.gov.au/business-government/secure-design/artificial-intelligence/deploying-ai-syste...>

SUP-01 / Pin and inventory executable dependencies

Scanner status: findings_detected | validation: static

1. Review lockfiles and exact versions or immutable digests for packages, images, MCP servers, models, and plugins.
2. Flag runtime installs, floating tags, remote scripts, and dependency sources outside approved registries.

<https://csrc.nist.gov/pubs/sp/800/218/final>



SUP-02 / Check vulnerability and maintenance exposure

Scanner status: manual_review_required | validation: manual

1. Run appropriate package/container advisory tools against resolved dependencies and save database date and tool version.
2. Triage reachability, fix availability, support status, and transitive dependencies; source pattern scans do not establish CVE coverage.

<https://www.ncsc.gov.uk/collection/guidelines-secure-ai-system-development>

SUP-03 / Verify artifact identity and provenance

Scanner status: findings_detected | validation: manual

1. Verify publisher identity, hashes/signatures, build provenance, and intended origin before enabling artifacts.
2. Review model loading and serialization behavior; an integrity hash cannot make an untrusted publisher safe.

<https://www.nsa.gov/Press-Room/Press-Releases-Statements/Press-Release-View/Article/4192332/nsas-aisc...>

<https://csrc.nist.gov/pubs/sp/800/218/final>

SUP-04 / Protect build, release, and configuration changes

Scanner status: no_pattern_detected | validation: hybrid

1. Restrict CI credentials and workflow permissions; review actions, build scripts, and release provenance.
2. Prevent untrusted contributions from executing with deployment secrets or changing approved agent policies.

<https://csrc.nist.gov/pubs/sp/800/218/final>

SUP-05 / Harden runtime isolation and deployment defaults

Scanner status: findings_detected | validation: hybrid

1. Review root/privileged containers, host mounts, Docker sockets, unrestricted egress, debug mode, and public management endpoints.
2. Separate agent execution from control-plane credentials and audit storage; test isolation in the deployed environment.

<https://www.cyber.gov.au/business-government/secure-design/artificial-intelligence/deploying-ai-syste...>

SUP-06 / Separate and protect model development environments

Scanner status: runtime_validation_required | validation: dynamic

1. When training or fine-tuning, isolate development, evaluation, and production identities, data access, registries, and release permissions.
2. Protect datasets, weights, adapters, and configuration separately; monitor modifications and demonstrate that an untrusted training job cannot replace an approved production artifact.

<https://csrc.nist.gov/pubs/sp/800/218/a/final>

OPS-01 / Produce attributable audit events

Scanner status: review_required | validation: hybrid

1. Record initiating identity, delegated identity, tool/server/version, approved arguments, decision, outcome, and correlation identifiers.
2. Protect log integrity and clock consistency; ensure agents cannot erase their own action history.

<https://owasp.org/projects/mcp-top-10>

OPS-02 / Bound work, spending, and concurrency

Scanner status: review_required | validation: hybrid

1. Set server-enforced limits for iterations, tokens, tool calls, recursion, parallelism, bytes, cost, and elapsed time.
2. Exercise stuck loops and amplification paths; verify limits apply across retries and child agents.

<https://www.cyber.gov.au/business-government/secure-design/artificial-intelligence/agent-ai-harnesses>

OPS-03 / Make cancellation and shutdown effective

Scanner status: runtime_validation_required | validation: dynamic

1. Provide a tested stop mechanism that revokes work, credentials, queued actions, and child tasks.
2. Measure stop latency and verify cancelled or disconnected requests cannot later commit prohibited side effects.

<https://www.cyber.gov.au/business-government/secure-design/artificial-intelligence/careful-adoption-o...>



OPS-04 / Fail safely and prevent duplicate side effects

Scanner status: runtime_validation_required | validation: dynamic

1. Deny or escalate when policy, identity, or approval checks fail; prevent fallback paths from widening privilege.
2. Test outages, partial failures, timeouts, retries, idempotency, and recovery of transactions with external effects.

<https://www.cyber.gov.au/business-government/secure-design/artificial-intelligence/agent-ai-harnesses>

OPS-05 / Monitor behavior and support rollback

Scanner status: runtime_validation_required | validation: dynamic

1. Alert on unusual tool use, new destinations, scope growth, repeated denials, cost spikes, and unexpected state changes.
2. Validate alerts with seeded events and test rollback of models, prompts, tools, policies, and poisoned memory.

<https://www.ncsc.gov.uk/collection/guidelines-secure-ai-system-development>

OPS-06 / Practice incident response and disclosure

Scanner status: manual_review_required | validation: manual

1. Maintain procedures to isolate agents, revoke credentials, preserve evidence, notify owners, and recover trusted state.
2. Exercise an AI-specific incident and define approved vulnerability/intelligence-sharing channels without exposing sensitive evidence.

<https://www.cisa.gov/news-events/alerts/2025/01/14/cisa-releases-jcdc-ai-cybersecurity-collaboration-...>

TEST-01 / Measure prompt-injection security and useful task completion

Scanner status: runtime_validation_required | validation: dynamic

1. Run paired benign and adversarial workflows with representative tools and attacker-controlled external content.
2. Record attacker success, authorized task success, blocked benign actions, and the observed unauthorized side effect.

<https://github.com/ethz-spylab/agentdojo>

<https://github.com/uiuc-kang-lab/InjecAgent>

TEST-02 / Test adaptively and repeat scenarios

Scanner status: runtime_validation_required | validation: dynamic

1. Vary payload wording, placement, modality, attacker knowledge, and attempts; rerun after changing defenses.
2. Report per-scenario outcomes, sample counts, attack budget, uncertainty, and model/harness versions instead of only an average.

<https://www.nist.gov/news-events/news/2025/01/technical-blog-strengthening-ai-agent-hijacking-evaluat...>

TEST-03 / Exercise MCP authentication and protocol abuse

Scanner status: runtime_validation_required | validation: dynamic

1. In an isolated test environment, exercise invalid tokens, wrong audiences, origin abuse, malicious servers, and protocol fuzzing.
2. Adapt scenarios to the deployed MCP revision and transports; preserve request/response evidence with secrets removed.

<https://github.com/AIS2Lab/MCPSecBench>

<https://modelcontextprotocol.io/specification/2026-07-28/basic/authorization>

TEST-04 / Verify cross-tenant and cross-agent isolation

Scanner status: runtime_validation_required | validation: dynamic

1. Create two principals and attempt cross-access to objects, memory, caches, handles, subscriptions, and execution results.
2. Repeat after reconnect, delegation, failed authentication, concurrent requests, and privilege revocation.

<https://github.com/agiresearch/ASB>

TEST-05 / Test approval, policy, and sandbox bypass

Scanner status: runtime_validation_required | validation: dynamic

1. Use explicit forbidden-action canaries to verify enforcement survives hostile content, tool substitution, and delayed execution.
2. Confirm paths through retries, fallback models, alternate tools, and child agents enforce the same boundary.

https://cheatsheetseries.owasp.org/cheatsheets/AI_Agent_Security_Cheat_Sheet.html



TEST-06 / Verify conventional application security

Scanner status: runtime_validation_required | validation: dynamic

1. Run language-aware SAST, dependency review, secret scanning, and authorized integration tests for exposed services.
2. Exercise reachable injection, XSS, SSRF, path traversal, deserialization, and access-control risks with safe fixtures.

<https://csrc.nist.gov/pubs/sp/800/218/final>

<https://genai.owasp.org/llmrisk/llm052025-improper-output-handling/>

TEST-07 / Validate resource exhaustion and observability

Scanner status: runtime_validation_required | validation: dynamic

1. Simulate oversized messages, slow peers, streaming floods, repeated errors, runaway agents, and unavailable dependencies.
2. Verify quotas, shutdown, telemetry, and alerts work together without leaking payloads or losing attribution.

<https://www.cyber.gov.au/business-government/secure-design/artificial-intelligence/autonomous-ai-harnesses>

TEST-08 / Evaluate the optional security judge itself

Scanner status: runtime_validation_required | validation: dynamic

1. Treat repository text and model verdicts as untrusted; test prompt injection, fabricated locations, invalid JSON, and timeouts.
2. Compare against labeled cases, retain deterministic results, document model variability, and never equate a judge approval with control validation.

<https://www.nist.gov/news-events/news/2025/01/technical-blog-strengthening-ai-agent-hijacking-evaluat...>

<https://nvlpubs.nist.gov/nistpubs/ai/NIST.AI.600-1.pdf>

TEST-09 / Evaluate model-layer attacks for hosted or customized models

Scanner status: runtime_validation_required | validation: dynamic

1. Where applicable, assess suspicious triggers, model extraction, and disclosure of private training examples under an explicit attacker access and query budget.
2. Retest acquired or retrained models and adapters before release; document measured failures, model identity, coverage limits, and accepted residual risk.

<https://cloudsecurityalliance.org/blog/2025/02/06/autonomous-ai-threat-modeling-framework-maestro>

<https://csrc.nist.gov/pubs/sp/800/218/a/final>